

LLMs Cannot Reliably Identify and Reason About Security Vulnerabilities (Yet?): A Comprehensive Evaluation, Framework, and Benchmarks

Saad Ullah Mingji Han Saurabh Pujar Hammond Pearce Ayse Coskun Gianluca Stringhini
Boston University Boston University IBM Research UNSW Sydney Boston University Boston University
saadu@bu.edu mjhan@bu.edu saurabh.pujar@ibm.com hammond.pearce@unsw.edu.au acoskun@bu.edu gian@bu.edu

Abstract—Large Language Models (LLMs) have been suggested for use in automated vulnerability repair, but benchmarks showing they can consistently identify security-related bugs are lacking. We thus develop SecLLMHolmes, a fully automated evaluation framework that performs the most detailed investigation to date on whether LLMs can reliably identify and reason about security-related bugs. We construct a set of 228 code scenarios and analyze eight of the most capable LLMs across eight different investigative dimensions using our framework. Our evaluation shows LLMs provide non-deterministic responses, incorrect and unfaithful reasoning, and perform poorly in real-world scenarios. Most importantly, our findings reveal significant non-robustness in even the most advanced models like ‘PaLM2’ and ‘GPT-4’: by merely changing function or variable names, or by the addition of library functions in the source code, these models can yield incorrect answers in 26% and 17% of cases, respectively. These findings demonstrate that further LLM advances are needed before LLMs can be used as general purpose security assistants.

1. Introduction

Large Language Models (LLMs), such as OpenAI’s Codex [1], Google’s PaLM2 [2], Meta’s Codellama [3], and StarCoder [4], etc., have demonstrated great potential in performing programming-language related tasks such as code generation, code documentation, and debugging. In 2022, around 1.2 million developers used Copilot, and since then we have witnessed the release of increasingly capable LLM models at a quick pace [2]–[5]. LLMs could be particularly useful to help developers with their cybersecurity needs, as humans typically produce and miss many security relevant bugs. This issue was highlighted in the 2022 GitHub Survey [6], noting that “developers do not find enough bugs early enough” and “do not prioritize the bug remediation” when developing. It is pertinent then to investigate if LLMs could be an aid towards early identification of security problems, especially as LLMs have already been suggested for use in automated bug repair [7].

In this paper, we aim to answer the following question: **Can LLMs be used as helpful security assistants for vulnerability detection?** This is an important question,

especially as LLMs are not infallible in security-related tasks, for example introducing vulnerabilities into source code [8], [9] and software testing [10]. Unfortunately, there is no standardized and automated approach to evaluate the performance of LLMs at identifying vulnerable code. We fill this gap by introducing SecLLMHolmes, a generalized, fully automated, and scalable framework to systematically evaluate the performance (i.e., accuracy and reasoning capabilities) of LLMs for vulnerability detection. Our framework tests the capabilities of a given LLM as a security assistant across eight distinct dimensions: (1) deterministic response, (2) performance over range of parameters, (3) diversity of prompts, (4) faithful reasoning, (5) evaluation over variety of vulnerabilities, (6) assessment of various code difficulty levels, (7) robustness to code augmentations, and (8) use in real-world projects.

We apply our framework to eight of the most capable LLMs across 228 code scenarios spanning over 8 most critical vulnerabilities in C and Python, and show that: (a) LLM performance varies widely depending on the model and the prompting technique used, however all models analyzed have a high false positive rate (FPR), and flag code where vulnerabilities have been patched as still vulnerable. (b) the output of LLMs is non-deterministic, with all models changing their answers over multiple runs for one or more of our tests. (c) even when they correctly identify a vulnerability, the reasoning that LLMs provide for this decision is often incorrect, questioning their trustworthiness. (d) LLM chain-of-thought reasoning [11] is not robust, and can be ‘confused’ by even simple code augmentations such as whitespace modification, changing function names, or using different but related library functions. Also, (e) LLMs fail at detecting vulnerabilities in real-world projects. Our study provides significant evidence that LLMs are not yet ready to be used for automated vulnerability detection, and the successful usage of our framework as a benchmark suite by future models would demonstrate meaningful progress in this space.

This paper makes the following contributions:

- We develop SecLLMHolmes, a comprehensive framework to test LLMs for their ability to identify and reason about software vulnerabilities. Our framework is fully automated and includes a set of 228 code scenarios,

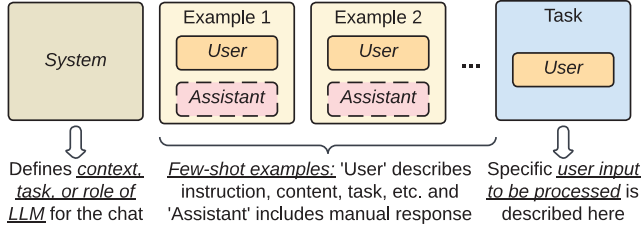


Figure 1: LLM chat input format. LLMs operate on a three-part input format: (1) a system prompt, (2) few-shot examples presented as chat history to guide the model’s learning, and (3) the specific user input/task to be processed.

- and 17 prompting techniques. We publicly release our framework and dataset¹, allowing the community to test newly developed LLMs and easily keep track of their progress in being able to identify vulnerabilities.
- We use our framework to test eight state-of-the-art LLMs for the task of vulnerability detection, showing that as of today no LLM achieves satisfactory performance at it.
 - We identify and enumerate a set of shortcomings that current LLMs show (as outlined above). Our observations provide a checklist for researchers working in this space, showing aspects that need to be addressed before LLMs can be considered ready to be used in the wild for the task of vulnerability detection.

2. Background and Related Work

Large Language Models (LLMs). All language models work on the basic principle of next word (token) prediction; i.e., given a sequence of words (tokens) $x_1, x_2, \dots, x_{n-1}$ select a word (token) x_n with the highest probability to appear next in the sequence

$$x_n = \arg \max_{w \in V} P(w|x_1, x_2, \dots, x_{n-1}),$$

where V is the vocabulary of the model. Language models learn to perform this task by training on a large amount of text data (i.e., natural language text or code) and use various techniques (e.g., attention mechanism [12]) to learn to focus on certain parts of the input for better output prediction. Language models have shown excellent proficiency in NLP tasks, as well as good results for programming language tasks such as code generation, code suggestion, natural language querying for code, etc.

The recent drastic increase in the number of parameters of models has enabled several remarkable capabilities, the most prominent of which being zero-shot and few-shot learning [13], [14]. LLMs are typically *prompted* (i.e., queried) by the user and provide a response—these advances enable the prompt to provide new knowledge or instructions that the model was not trained over.

Approaches like instruction-tuning ‘teach’ LLMs how to follow instructions in their prompt responses, and reinforcement learning from human feedback is used to ‘teach’

1. <https://github.com/ai4cloudops/SecLLMHolmes>

TABLE 1: Studied LLMs. We select a number of capable chat-based LLMs, both Remote and Local, for our study, with diverse ranges of number of parameters, max. input tokens limits, and different training knowledge cut-offs. Oct. 7, 2023 is the date of access for all LLMs.

Model API	Base Model	# Params	Max. Tokens	Type	Knowledge Cut Off
gpt-4	GPT-4	1.76T	8,192	Rem	09/2021
gpt-3.5-turbo-16k	GPT-3.5	175B	16,385	Rem	09/2021
codechat-bison@001	PaLM2	340B	6,144	Rem	mid-2021
chat-bison@001	PaLM2	340B	6,144	Rem	mid-2021
codellama-7b-instruct	Llama2	7B	100k	Loc	01/2022
codellama-13b-instruct	Llama2	13B	100k	Loc	01/2022
codellama-34b-instruct	Llama2	34B	100k	Loc	01/2022
starchat-beta	StarCoder+	15.5B	8,192	Loc	09/2022

them how to answer, converse, and reason like humans. This has led to the creation of several chat-based LLMs, which can interact conversationally with human inputs (see Figure 1). The chat-based LLMs can be prompted using various techniques:

- In **Zero-Shot (ZS)** scenario, the user asks a model to perform a task that the model might not have observed during pre-training.
- In **Few-Shot (FS)** scenario, the user adds a few examples demonstrating input space and expected output to perform a specific task (as shown in Figure 1).
- **Task-Oriented (TO)** scenarios explicitly assign a task to the model (either in ‘system’ or ‘user’ prompt) in the form of a statement or a question, which encourages the model to generate a task-specific response.
- **Role-Oriented (RO)** scenarios assign a role to the model, e.g., helpful assistant, security expert, etc., and the model implicitly understands the expected behavior. This role is mostly assigned in the ‘system’ prompt.

Table 1 shows the details of the currently most capable chat-based LLMs that we investigate in this paper.

Vulnerability Detection. One of the biggest challenges during the development and maintenance of software systems is the process of detecting security bugs and identifying their root cause [6]. OWASP [15] presents a list of static and runtime analysis tools and techniques that work in this space. Most of these tools transform source code into a specific representation, e.g., abstract syntax tree, program dependency graph, code property graph, etc., and scan them to identify pre-defined insecure patterns. For instance, Yamaguchi *et al.* introduce Joern, a tool that uses code property graphs [16] to identify several vulnerability patterns in C/C++ code.

Unfortunately, these techniques require considerable manual effort and curation of security bug datasets, especially if they are based on trained supervised Machine Learning (ML) models. Examples of methods that use supervised ML include VulChecker [17], VulDeePecker [18], Poster [19], and SySeVR [20]. As the ratio of vulnerable to non-vulnerable examples is very low in the real world, the vulnerable examples in these datasets are not sufficient for ML models to learn the necessary information. Suggested improvements in this category include using pre-trained LLMs for code and ‘fine-tuning’ them on security bug

TABLE 2: Evaluation studies for code security. This table describes if the evaluation is (✓) semi or (✓) fully) Automated, Evaluates Reasoning (root cause) ✓ or only performs binary evaluation ✗, tests Code-level Robustness, evaluates both ✓ or just one ✓ of the Vulnerable and Patched code scenarios, evaluates on Real-World CVEs ✓ or github mined potential defect commits [33] ✓, and # of Code Scenarios included in the study, which are not generated by synthetic AI methods or labeled using out-dated research tools.

Study	Auto	Eval Reas.	Code Robust	Vuln- Patch	Real World	# Scen.
Vuln. Code Gen. [8]	✓	✗	✗	✓	✗	89
Vuln. Code Repair [7]	✓	✗	✗	✓	✓	syn.
Limits of ML [30]	✓	✗	✓	✓	✓	res.
Transf. Vuln. Det. [34]	✓	✗	✗	✓	✓	res.
SecLLMHolmes	✓	✓	✓	✓	✓	228

datasets for the downstream task of vulnerability detection. Notable approaches here are UniXCoder [21], VulBERTa [22], and CoText [23].

Evaluating for Code Security. Evaluating approaches for identifying security weaknesses in code requires testing their performance on multiple axes. For instance, what are their accuracy and false positive rate (FPR)? Are reasons/root causes for a vulnerability provided by the tool, and if so, at what quality? Is the tool robust to noise in testing data? How many types of vulnerabilities can it detect? Static analysis tools have always struggled with the trade-off between accuracy and coverage. Tools either focus on high accuracy and low coverage (e.g., Pysa [24] by Meta, which identifies data-flow issues in Python applications), or (b) low accuracy (false positives) and high coverage (e.g., [25]–[27]), which can lead to developer frustration and wasted time.

ML-based static analysis tools [18], [28] not only face the accuracy-coverage trade-off but also struggle with *robustness*. Such tools have demonstrated good performance on research datasets but can fail to generalize and perform well over real-world datasets [29]. Risse *et al.* [30] identify the same issue of non-robustness in LLM-based vulnerability detection tools [22], [23], [31], and showcase the drop in accuracy with even trivial code augmentations. Moreover, Microsoft’s leader-board for LLM-based vulnerability detection tools [32] shows that the even the best tool has an accuracy of less than 70% and 30%+ FPR, which shows that these systems cannot be trusted in real-world cases.

Recent works have evaluated LLMs for vulnerable code generation [8], code repair [7], and vulnerability detection [34]. However, these approaches are either limited by the number of LLMs, coverage of vulnerabilities, diversity of prompts, range of code complexities, robustness testing, or require manual labor for evaluating LLMs. Most importantly, these studies only evaluate binary responses, checking whether the LLM gives the right label to code snippets (e.g., ‘vulnerable’ or ‘not vulnerable’). In this paper, we present the first comprehensive evaluation framework to evaluate LLMs on the task of vulnerability detection, providing a multi-faceted analysis of the capabilities of LLMs, including going beyond binary decisions and evaluating their rea-

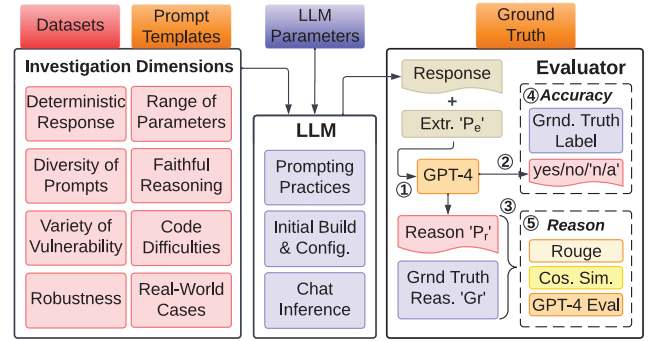


Figure 2: SecLLMHolmes Architecture.

soning abilities. Table 2 summarizes evaluation studies of LLMs, highlights their short-comings, and compares against our framework.

In addition to presenting a new state-of-the-art framework, our study uncovers previously unidentified challenges associated with LLMs, including their inability to understand complex code data-flows, the fragility of their COT or step-by-step reasoning to even trivial augmentations, a bias towards security-related functions and variable names that overlooks actual vulnerabilities, a reasoning process that diverges from the methodology of real-world human security experts, particularly in accurately identifying correct root cause of a vulnerability.

3. SecLLMHolmes

Figure 2 presents an overview of our fully automated framework, SecLLMHolmes, which is designed to be applicable to any chat-based LLM. Section 3.1 describes how users can configure an LLM for integration. The core of our framework consists of five pre-defined key components: (i) a set of parameters (Section 3.2), (ii) an extensive set of prompt templates (Section 3.3), (iii) datasets (Section 3.4), and (iv) code augmentations (Section 3.4), all of which facilitate the generation of test *prompts*. Each prompt is then passed to the LLM to generate a response, and the quality of the response is then analyzed by the (v) ‘Evaluator’ module (Section 3.6).

3.1. LLM configuration

To scale SecLLMHolmes for any chat-based LLM, we have established three configurable user inputs:

LLM-Specific Best ‘Prompting Practices’ and Rules. As each LLM may be tuned differently with respect to instruction following, this configurable input enables users to configure optimal prompting practices for the specific LLM they are integrating. This may be done following the LLM’s documentation. For example, OpenAI’s GPT documentation recommends the use of three quotes before and after the given content to separate it from the instruction [35], while Google’s PaLM2 documentation recommends the use of

keywords before the content that describe its semantics such as ‘Code,’ ‘Text,’ ‘Question’ [36].

LLM ‘Initialization and Configuration.’ All LLMs require an initial setup; for example, remote models may require an API key (e.g. OpenAI) or to initialize a session with a specific project in the cloud (e.g. Google). Local models require loading the model, tokenizer checkpoints, etc. This input allows user to specify such configuration details.

LLM ‘Chat Structure and Inference Function.’ To generate a response, each chat-based LLM receives three inputs: ‘system,’ ‘few-shot examples,’ and ‘task’ prompts (as shown in Figure 1). In this function, users specify how these three inputs are passed to the configured LLM (via API for remote models or ‘text-generation’ pipeline for local models).

3.2. LLM Parameters

LLM responses are significantly impacted by two parameters which control token sampling: (1) **temperature** controls the determinism of an LLM’s output. A higher value of temperature generates more ‘creative’/‘random’ text by adding noise to potential token scores (2) **top_p** controls the nucleus sampling, where the LLM considers the results of the tokens with top_p probability mass. We discuss how we select the values of these parameters in Section 4.

3.3. Prompt Templates

SecLLMHolmes explores four techniques for LLM prompting: (1) **zero-shot task-oriented (ZS - TO)**, (2) **zero-shot role-oriented (ZS - RO)**, (3) **few-shot task-oriented (FS - TO)**, and (4) **few-shot role-oriented (FS - RO)**. Moreover, we divide our set of prompts in the following three categories (all prompts are described in Table 3):

Standard (S) prompting asks the model to directly give an answer to the problem.

Step-by-Step Reasoning-based (R) prompting asks the model to solve the problem in a step-by-step manner using chain-of-thought (COT) reasoning [11], [37], [38]. In addition to evaluating the intrinsic step-by-step reasoning process of LLMs, we also create prompts that emulate the multi-step vulnerability detection method followed by human security-experts, as identified in prior qualitative studies [39], [40]. These studies observed that security experts follow a general multi-step vulnerability detection approach, i.e., (1) get an overview of the code, (2) based on the overview, identify the critical sub-components that can lead to a security vulnerability in code, e.g., copying user provided information into a buffer, etc., (3) perform a detailed analysis of these sub-components, e.g., if a user input is being copied into a buffer the security experts will check if in any scenario the user input can overflow the buffer, and then, (4) based on the detailed experiments, provide the final answer on whether the given code contains any instances of the given security vulnerability.

Definition-based (D) prompting provides additional information like the definition of a security vulnerability from

TABLE 3: Prompt templates.

ID	Type	Description
S1	ZS-TO	Code snippet is added to the input prompt with a question about a specific Common Weakness Enumeration (CWE) (e.g., out-of-bound write, path traversal).
S2	ZS-RO	Same as S1, but the LLM is assigned the role of a ‘helpful assistant’.
S3	ZS-RO	Similar to S1, with the LLM acting as a ‘security expert’.
S4	ZS-RO	The LLM is defined as a ‘security expert’ who analyzes a specified security vulnerability, without the question being added to the input prompt.
S5	FS-TO	Similar to S1, but includes a vulnerable example, its patch, and standard reasoning from the same CWE.
S6	FS-RO	Like S4, but also includes a vulnerable example, its patch, and standard reasoning from the same CWE.
R1	ZS-TO	Similar to S1, but begins with “Lets think step by step” [37] to encourage a methodical approach.
R2	ZS-RO	The LLM plays the role of a security expert with a multi-step approach to vulnerability detection, following a chain-of-thought reasoning.
R3	ZS-TO	A multi-round conversation with the LLM, starting with a code snippet and progressively analyzing sub-components for a security vulnerability like human security-experts.
R4	FS-RO	Similar to S6, but the reasoning for answers involves step-by-step analysis developed by the first author.
R5	FS-RO	Like R2, but includes few-shot examples (from the same CWE) with step-by-step reasoning for detecting vulnerabilities.
R6	FS-TO	Similar to R5, but does not assign a specific role to the LLM in the system prompt.
D1	ZS-TO	Adds the definition of a security vulnerability to the input prompt, followed by a related question.
D2	ZS-RO	The LLM is a security expert analyzing code for a specific vulnerability, with the vulnerability’s definition included.
D3	FS-RO	Similar to S6, but includes the definition of the security vulnerability in the system prompt.
D4	FS-RO	Like R4, with the addition of the security vulnerability’s definition in the system prompt.
D5	FS-TO	Similar to D4, but does not assign a specific role to the LLM in the system prompt.

MITRE’s official website [41] to the model, while asking the model to detect that vulnerability in the given code.

3.4. Datasets

We design 228 code scenarios (48 hand-crafted, 30 real-world, and 150 with code augmentations) to test various aspects of the capabilities of LLMs to detect software vulnerabilities in code. We use these scenarios to craft prompts by including code, examples, definitions, and step-by-step reasoning as shown in Table 3. In the following, we describe how we built our code scenarios in detail.

Hand-Crafted CWE Scenarios. We curate a dataset of 48 hand-crafted code scenarios, containing vulnerable and patched pairs from 8 most critical and diverse Common

TABLE 4: Hand-crafted dataset.

CWE ID	Description	MITRE Rank	Lang.
787	Out-of-bounds Write	1	C
79	Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')	2	Py
89	Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')	3	Py
416	Use After Free	4	C
22	Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')	8	C
476	NULL Pointer Dereference	12	C
190	Integer Overflow or Wraparound	14	C
77	Improper Neutralization of Special Elements used in a Command ('Command Injection')	16	C

Weakness Enumerations (CWEs) from the MITRE Top 25 Most Dangerous Software Weaknesses for the year 2023 [41], as shown in Table 4. To investigate the ability of LLMs to analyze multiple programming languages, we include examples from both C and Python.

Similar to previous work [8], we create six code scenarios (three pairs of vulnerable and patched scenarios) for each CWE. Moreover, we design our code scenarios with three difficulty levels, (1) easy, (2) medium, (3) hard. Code scenario '2_v' in a specific CWE represents the vulnerable scenario with 'medium' difficulty level and '2_p' its patch. The difficulty levels assess how LLMs interact with code of increasing complexity. *Easy* scenarios consist of simple programs containing only one function and less than 30 lines of code. *Medium* level scenarios increase the complexity by making the program longer, using different library functions, and adding more than one user input. *Hard* level introduces scenarios with multiple functions in which functions can be safe on an individual level but when they work together they make the program vulnerable.²

Real-World CVE Scenarios. We leverage a set of real-world Common Vulnerabilities and Exposures (CVEs) from public open source projects to investigate if LLMs are able to identify vulnerabilities in them. Note that existing benchmarks for vulnerability detection [18], [33], [42], [43], cannot be used for this project, as they were released before the cut-off training date of current LLMs, and it is therefore likely that the models saw that data during training. To avoid this potential confounder, we curate 30 code scenarios containing vulnerable and patched versions of 15 CVEs from four open source projects, all published and fixed in 2023, after current LLMs were trained (see Table 5).

As the length of the code increases significantly for the real-world code scenarios, it can exceed the maximum number of tokens a model can take as an input. To solve this problem, we shorten code files by removing comments and functions that are neither called by nor call the vulnerable (or patched) function. Also to maintain fairness among the LLMs, we make sure that all CVEs after truncation have a number of tokens less than or equal to 6,144, which is the

TABLE 5: Real-world CVEs and their details including Original and Truncated Lines of Code (LoC).

Project	CVE ID	CWE Description (ID)	Orig. LoC	Trun. LoC	Pub. Date (2023)	Fix Date (2023)
gpac	2023-1452	Out-of-Bound Write (787)	4.5k	243	Mar	May
	2023-3012	NULL Pointer Deref (476)	2.5k	398	May	Nov
	2023-23143	Out-of-Bound Write (787)	12.3k	117	Jan	May
	2023-23144	Integer Overflow (190)	439	389	Jan	May
libtiff	2023-2908	NULL Pointer Deref (476)	2.3k	629	Jan	Nov
	2023-3316	NULL Pointer Deref (476)	159	159	Jan	Nov
	2023-26966	Out-of-Bound Write (787)	1.8k	238	Jun	Nov
	2023-40745	Integer Overflow (190)	2.2k	757	Oct	Nov
	2023-41175	Integer Overflow (190)	779	748	Oct	Nov
linux	2023-40283	Use-After-Free (416)	1.9k	515	Aug	Nov
	2023-42753	Integer Overflow (190)	628	623	Sept	Nov
	2023-42754	NULL Pointer Deref (476)	3.7k	177	Oct	Nov
	2023-45863	Out-of-Bound Write (787)	1.1k	565	Oct	Nov
	2023-45871	Out-of-Bound Write (787)	10.1k	386	Oct	Nov
psip	2023-27585	Out-of-Bound Write (787)	784	737	Mar	Aug

maximum token limit supported by Palm2, and the lowest among all LLMs in our study.

Code Augmentations. While standard frameworks exist to evaluate the robustness of LLMs for NLP tasks [44], [45], there is no standard framework to evaluate the robustness on code security related tasks. To fill this gap, we design a set of 150 augmented code scenarios, meticulously crafted and reviewed to preserve the ability of human security experts to identify vulnerabilities. These augmentations are organized in two distinct categories:

- 1) **Trivial Augmentations.** This class of code augmentations measure the robustness of LLMs to random noise. We select 12 CWE scenarios from two classes, i.e., CWE-787 (C) (#1 MITRE) and CWE-89 (Py) (#3 MITRE) of our hand-crafted dataset, and apply seven trivial augmentations (Table 6) on them and create a total of 84 different code scenarios (12 per augmentation). We choose these two CWEs as (1) they can lead to the most catastrophic impacts like root privilege escalation, and data loss, etc, (2) they belong to two completely different levels of abstractions i.e., "lower-level" (C) and "higher-level" (Python) languages, and (3) the presence of their instances can be determined directly from code without any need for external information.
- 2) **Non-Trivial Augmentations.** We design non-trivial code augmentations to perform stress-tests on LLMs to measure their robustness and bias towards semantics of function or variable names, specific library functions, or code security practices. We use combinations of all CWEs defined in Table 4 and the six non-trivial code augmentations from Table 6 and design 66 code scenarios (12 per NT1-NT4 and 9 per NT5 and NT6)³.

3. See Appendix B for details on creation of non-trivial augmented code scenarios

2. Appendix A shows examples of all difficulty levels for 'CWE-22'.

TABLE 6: Code Augmentations.

Trivial		Non-Trivial	
ID	Description	ID	Description
T1	Rename function parameters randomly	NT1	Change variable names to vulnerability related keywords
T2	Rename function randomly	NT2	Change the name of a safe function to 'vulnerable' function
T3	Add random unreachable code	NT3	Change the name of an unsafe function to 'non_vulnerable' function
T4	Add random code in comments	NT4	Add a potentially dangerous library function (e.g., 'strcpy' or 'streat') but use it in a safe way
T5	Insert whitespaces	NT5	Use sanitizing functions (e.g., 'realpath') in vulnerable code but in a way that it does not resolve the vulnerability
T6	Add a useless function	NT6	Add hash-defined expressions for safe functions names (e.g., 'fgets') but add vulnerable library functions in its body (e.g., 'gets')
T7	Add next-line character		

3.5. Ground-Truth Reasoning G_r

In addition to ground truth labels indicating if a code snippet contains a vulnerability, we also need explanations for these vulnerabilities, as we aim to evaluate the reasoning capabilities of LLMs and assess whether they can justify their decisions. To this end, we randomly sample 48 code scenarios out of the 228 total scenarios, and have three security experts, including the first author of the paper equally divide the sampled code scenarios amongst each other and create a 100-word ground truth reason for each scenario using MITRE's official CWE documentation [41] as a guide. The experts then compare and discuss each others' reasoning and develop consensus for each ground-truth reasoning (Fleiss' kappa with $K = 0.93$, meaning almost perfect agreement [46]). After establishing that the criteria for ground truth reasoning are well laid out and understood, the first author proceeds to develop the remaining 180 vulnerability explanations. This ground truth reasoning G_r is then used by the 'Evaluator' module in the next step.

3.6. Evaluator

The output of an LLM for a specific test is passed to the Evaluator (see Figure 2). As SecLLMHolmes is fully automated, we leverage GPT-4 to analyze the response. First, the ① response is passed to GPT-4⁴, with an additional role-based instruction prompt P_e (shown in Figure 8 in the Appendix) in the 'system' input to extract two pieces of information from the raw response. The first one is the ② binary answer, which is "yes/no" based on whether the LLM found a vulnerability in the given code or not. We find that in some cases the LLM does not provide a definite answer, therefore we include a third verdict, i.e., "n/a."⁵ The second part of the information extracted is the ③ textual reasoning

4. Our manual evaluation shows that GPT-4 performs the best for this extraction process.

5. For example, in some cases LLMs provide some variation of the following response: "As an AI model I cannot answer this question."

provided by the LLM (P_r). To extract it, we ask GPT-4 to summarize the reason described by the model output on why a vulnerability is present in the code or not, in 100 words. We extract the summary of root cause of vulnerability from raw responses of LLMs to maintain consistency for further evaluation methods, and to avoid contents like suggestions, fixed code, etc. to be analyzed. In the rest of this section we provide more details on the evaluation metrics used to ④ evaluate the final answer, and ⑤ its reasoning provided by LLM for the vulnerability detection task.

Accuracy Score. To evaluate the accurate detection of a vulnerability in source code, we compare the answer extracted from the response of the LLM (i.e., "yes/no/n/a") with the ground truth labels and use the "accuracy" metric, i.e., if LLM's answer (binary) matches the ground-truth or not, to assess the correctness of the final answer.

Reasoning Score. Automatically evaluating if the textual reasoning provided by the LLM on whether a vulnerability is present is a challenging task. To solve this task we use GPT-4 to summarize the reason (P_r) provided by an LLM and compare it with the ground-truth reasoning (G_r) generated by the authors, using the following three metrics:

- 1) **Rouge** [47] score is traditionally used in NLP to measure the similarity between a machine-translated summary and reference summaries using overlapping n-grams. In our case, we use it to measure similarity between the summaries P_r and G_r . We first sample 50 pairs of P_r and their corresponding G_r , as our reasoning score validation set (R_{val}), and manually check the consistency and alignment of their reasonings. We find that at the optimal threshold $Rouge_{thres}$ of 0.34, 43 out of 50 P_r are consistent with G_r . We therefore use this threshold and mark two summaries as similar if their Rouge score exceeds it.
- 2) **Cosine Similarity** is a metric commonly used in NLP to measure how similar two documents are irrespective of their sizes. We first convert the summaries P_r and G_r into fixed length vectors using OpenAI's embedding model 'text-similarity-davinci-001' and calculate the cosine similarity between them. Similar to $Rouge_{thres}$, we find that the optimal threshold Cos_{thres} is 0.84, and consider two summaries similar if their cosine similarity exceeds this value.
- 3) **GPT-4** is prompted to evaluate if the reasoning in P_r and G_r align. If the reasonings are similar and they align with each other, GPT-4 responds 'yes' and we assign a reasoning score of 1, otherwise we assign 0. We find that GPT-4 successfully classifies 48 out of 50 P_r correctly to their corresponding G_r , when validated on R_{val} .

We then determine whether the reasoning by the LLM is correct or not by majority vote. That is, if two or more of the above criteria match, we consider the reasoning as similar to the ground truth reasoning G_r .

4. Experimental Investigation

In this section, we use our framework to investigate all LLMs listed in Table 1.⁶ We first investigate which values of the LLM parameters are most likely to produce consistent (Section 4.1) and best performing (Section 4.2) output. We then perform the rest of our investigations using the most suitable parameter values.

4.1. Evaluation for Deterministic Responses

To perform a rigorous comparison between LLMs and assess their capabilities, it is of critical importance that their responses are consistent, meaning that running the same test multiple times under identical parameters should provide the same final verdict. Therefore, we first investigate whether this consistency is achievable at all, and what LLM parameters deliver the most consistent results. OpenAI’s documentation [48] recommends a temperature of 0.2 and ‘top_p’ of 0.1 to achieve the most deterministic output for code related tasks. Similarly, the recommended ‘temperature’ value for all LLMs in our evaluation is 0.2. When experimenting with modifying these values, both the OpenAI documentation [49] and previous research [7] recommend to keep the value of ‘top_p’ constant and modify the value of ‘temperature.’ We therefore fix ‘top_p’ to default value specific to an LLM, and perform experiments using two different ‘temperature’ values: 0.2 (‘default’) and 0.0. We perform this experiment on two vulnerable and two patched medium code difficulty level scenarios (2_v and 2_p) from two distinct vulnerabilities, “out-of-bound write” (CWE-787) in C and “SQL injection” (CWE-89) in Python (for the same reasons as discussed in Section 3.4). For the input prompts we select the set of Standard prompts (see Section 3.3). We run each experiment ten times, and record how many times the model provides the same answer. We consider a model to be consistent if it always provides the same binary answer, irregardless of whether it is correct.

Observations. Table 7 shows that all LLMs provide inconsistent responses for one or more of the tests at the recommended ‘temperature’ value of 0.2. ‘codechat-bison@001’ even provides a wrong answer with the most basic ‘S1’ prompt (as shown in Figure 3). This suggests that the default ‘temperature’ is not a good choice to evaluate LLMs for vulnerability detection. Using 0.0 as temperature improves consistency, as shown in Table 8: ‘codechat-bison@001,’ ‘codellama34b,’ and ‘gpt-3.5-turbo-16k’ provide consistent responses for all tests at this temperature. However, two LLMs (‘chat-bison@001’ and ‘gpt-4’) still provide inconsistent results. Based on these results, we find that 0.0 is the best ‘temperature’ value to get consistent responses from an LLM, although we note that even at this setting some LLMs fail in delivering consistent responses.

6. We only report the results for the five best performing LLMs in the main body of the paper. The ones for the remaining three LLMs can be found in the Appendix.

TABLE 7: Evaluation Results for LLM Output Consistency at Recommended Temperature. The table shows results for each CWE scenario and every Standard prompt, in the format of # correctly answered / # total answered out of 10.

(a) CWE-787												
Models	S1		S2		S3		S4		S5		S6	
	2_v	2_p	2_v	2_p	2_v	2_p	2_v	2_p	2_v	2_p	2_v	2_p
chat-bison	10/10	0/10	10/10	0/10	10/10	0/10	10/10	0/10	2/10	8/10	10/10	0/10
codechat-bison	9/10	0/10	10/10	0/10	10/10	0/10	10/10	0/10	9/10	0/10	10/10	0/10
codellama34b	10/10	0/10	10/10	0/10	10/10	0/10	10/10	0/10	10/10	0/10	5/10	7/10
gpt-3.5	0/10	10/10	0/10	10/10	0/10	10/10	0/10	10/10	0/10	10/10	10/10	0/10
gpt-4	0/10	10/10	6/10	10/10	1/10	10/10	6/10	10/10	0/10	10/10	7/10	10/10

(b) CWE-89												
Models	S1		S2		S3		S4		S5		S6	
	2_v	2_p	2_v	2_p	2_v	2_p	2_v	2_p	2_v	2_p	2_v	2_p
chat-bison	10/10	10/10	10/10	8/10	10/10	10/10	10/10	0/10	10/10	10/10	0/10	10/10
codechat-bison	10/10	10/10	10/10	2/10	10/10	7/10	10/10	0/10	10/10	10/10	10/10	10/10
codellama34b	10/10	0/10	10/10	0/10	10/10	0/10	10/10	0/10	10/10	10/10	10/10	0/10
gpt-3.5	10/10	10/10	10/10	10/10	10/10	10/10	10/10	1/10	10/10	10/10	10/10	7/10
gpt-4	10/10	10/10	10/10	10/10	10/10	0/10	10/10	10/10	10/10	10/10	10/10	5/10

TABLE 8: Evaluation Results for LLM Output Consistency at Temperature = 0.0.

(a) CWE-787												
Models	S1		S2		S3		S4		S5		S6	
	2_v	2_p	2_v	2_p	2_v	2_p	2_v	2_p	2_v	2_p	2_v	2_p
chat-bison	10/10	0/10	10/10	0/10	10/10	0/10	10/10	0/10	0/10	10/10	9/10	0/10
codechat-bison	10/10	0/10	10/10	0/10	10/10	0/10	10/10	0/10	0/10	10/10	0/10	10/10
codellama34b	10/10	0/10	10/10	0/10	10/10	0/10	10/10	0/10	0/10	10/10	0/10	10/10
gpt-3.5	0/10	10/10	0/10	10/10	0/10	10/10	0/10	10/10	0/10	10/10	10/10	0/10
gpt-4	0/10	10/10	8/10	10/10	2/10	10/10	4/10	9/10	0/10	10/10	4/10	10/10

(b) CWE-89												
Models	S1		S2		S3		S4		S5		S6	
	2_v	2_p	2_v	2_p	2_v	2_p	2_v	2_p	2_v	2_p	2_v	2_p
chat-bison	10/10	10/10	10/10	0/10	10/10	10/10	10/10	0/10	10/10	10/10	10/10	10/10
codechat-bison	10/10	10/10	10/10	0/10	10/10	0/10	10/10	0/10	10/10	10/10	10/10	0/10
codellama34b	10/10	0/10	10/10	0/10	10/10	0/10	10/10	0/10	10/10	10/10	10/10	0/10
gpt-3.5	10/10	10/10	10/10	10/10	10/10	10/10	10/10	0/10	10/10	10/10	10/10	10/10
gpt-4	10/10	10/10	10/10	10/10	10/10	0/10	10/10	10/10	10/10	10/10	10/10	9/10

4.2. Performance Over Range of Parameters

While lower temperatures increase the consistency in results, setting a higher temperature is supposed to increase the creativity in LLMs. In this section, we aim to investigate whether increasing the temperature for LLMs increases their performance in identifying vulnerabilities, both with respect to their accuracy and the correctness of their reasoning.

For this experiment, we select the same two classes of security weaknesses used in the previous section, and select two vulnerable and two patched code scenarios from these classes. We choose scenarios with the highest code difficulty level (3_v and 3_p) as they would need more creativity to be correctly solved by LLMs.

As running experiments on all prompts is not feasible due to budget constraints, we perform the experiment on only one prompt, S4 (ZS-RO), based on three reasons; (1) this prompt does not provide any additional information like definition or step-by-step reasoning instructions to the LLM, so the response will be mainly based on the intrinsic


```

1  ...
2  int MAX_SIZE = 32;
3  char* encode_input(char *user_supplied_string){
4      int i, dst_index;
5      char* dst_buf = (char*)malloc((4 * sizeof(char) *
6          MAX_SIZE) + 1);
7      if ( MAX_SIZE <= strlen(user_supplied_string) )
8          exit(1);
9      dst_index = 0;
10     for ( i = 0; i < strlen(user_supplied_string); i++ ){
11         if('&' == user_supplied_string[i]){
12             dst_buf[dst_index++] = '&';
13             dst_buf[dst_index++] = 'a';
14             dst_buf[dst_index++] = 'm';
15             dst_buf[dst_index++] = 'p';
16             dst_buf[dst_index++] = ';';
17         } else if ('<' == user_supplied_string[i]){
18             /* replace with &lt; */
19         } else if ('>' == user_supplied_string[i]){
20             /* replace with &gt; */
21         } else dst_buf[dst_index++] =
22             user_supplied_string[i];
23     }
24     dst_buf[dst_index] = '\0';
25     return dst_buf;
26 }

```

(a) CWE-787 (Out-of-Bound Write) 2_p: This code scenario encodes certain characters in the user input string. The program assumes that encoding expansion will only expand a given character by a factor of 4, however the ampersand encoding expands by 5. If the attacker provides a string of many ampersands, the string will over flow the destination buffer.

codechat-bison (1st Response)

Yes, the code contains instances of the security vulnerability known as out-of-bounds write. The code allocates a buffer of size (4 * sizeof(char) * MAX_SIZE) + 1 bytes. However, the code does not check to ensure that the length of the input string does not exceed the size of the buffer. This could lead to an out-of-bounds write if the input string is longer than the buffer.



codechat-bison (5th Response)

No, the code does not contain instances of the security vulnerability known as out-of-bounds write. The code is safe because the 'dst_index' variable is used to keep track of the current position in the destination buffer. This variable is incremented each time a character is copied from the source buffer to the destination buffer. This ensures that no characters are written outside of the bounds of the destination buffer.



(b) 'codechat-bison@001' responses.

Figure 3: Non-deterministic and inconsistent responses by 'codechat-bison@001'.

knowledge of the model from its training data and no external instruction or information will influence its reasoning or creativity at a higher temperature, (2) being a zero-shot prompt it does not limit the creativity or reasoning of the model as in few-shot prompting might influence the model to mimic the few-shot examples, and (3) this prompt is the most non-deterministic zero-shot prompt as shown in Tables 8 and 7, allowing it to show more randomness or creativity at higher temperature. We evaluate LLMs on six temperature values: their recommended value 0.2, and over a range of values from 0 to 1 i.e., 0, 0.25, 0.5, 0.75, 1.0. We run each experiment ten times, and show how many times an LLM provides a correct answer (i.e., accuracy) and correct reasoning (i.e., reasoning score). The results are summarized

TABLE 9: Evaluation of LLMs Over a Range of Temperature Values (CWE-787). The table shows results for each temperature value in the format of # correct / # total answered out of 10.

Model	Rec	0.0	0.25	0.5	0.75	1.0
chat-bison	2/3	10/10	0/0	4/5	4/5	4/6
codechat-bison	0/1	10/10	2/2	1/2	2/3	4/4
codellama34b	10/10	10/10	10/10	10/10	10/10	9/10
gpt-3.5	0/10	0/10	2/10	5/10	5/10	8/10
gpt-4	10/10	10/10	10/10	10/10	10/10	10/10

(a) Accuracy (3_v)

Model	Rec	0.0	0.25	0.5	0.75	1.0
chat-bison	2/3	10/10	0/0	4/5	4/5	4/6
codechat-bison	0/1	10/10	2/2	1/2	2/3	4/4
codellama34b	10/10	10/10	10/10	10/10	10/10	9/10
gpt-3.5	0/10	0/10	2/10	5/10	6/10	8/10
gpt-4	10/10	10/10	10/10	10/10	10/10	10/10

(b) Reason (3_v)

Model	Rec	0.0	0.25	0.5	0.75	1.0
chat-bison	0/4	0/10	0/4	0/0	0/5	1/4
codechat-bison	0/1	0/10	0/5	0/2	1/7	2/8
codellama34b	0/10	0/10	0/10	1/10	0/10	2/10
gpt-3.5	9/10	10/10	9/10	9/10	6/10	6/10
gpt-4	0/10	0/10	0/10	0/10	0/10	0/10

(c) Accuracy (3_p)

Model	Rec	0.0	0.25	0.5	0.75	1.0
chat-bison	6/10	0/10	6/10	10/10	5/10	7/10
codechat-bison	9/10	0/10	5/10	8/10	4/10	4/10
codellama34b	0/10	0/10	0/10	0/10	1/10	1/10
gpt-3.5	9/10	10/10	9/10	9/10	6/10	6/10
gpt-4	0/10	0/10	0/10	0/10	0/10	0/10

(d) Reason (3_p)

TABLE 10: Evaluation of LLMs Over a Range of Temperature Values (CWE-89).

Model	Rec	0.0	0.25	0.5	0.75	1.0
chat-bison	10/10	10/10	10/10	10/10	6/9	7/9
codechat-bison	10/10	10/10	9/10	10/10	8/9	9/10
codellama34b	10/10	10/10	10/10	10/10	10/10	10/10
gpt-3.5	10/10	10/10	10/10	10/10	10/10	10/10
gpt-4	10/10	10/10	10/10	10/10	10/10	10/10

(a) Accuracy (3_v)

Model	Rec	0.0	0.25	0.5	0.75	1.0
chat-bison	10/10	10/10	10/10	10/10	6/9	7/9
codechat-bison	10/10	10/10	9/10	10/10	8/9	9/10
codellama34b	10/10	10/10	10/10	10/10	10/10	10/10
gpt-3.5	10/10	10/10	10/10	10/10	10/10	10/10
gpt-4	10/10	10/10	10/10	10/10	10/10	10/10

(b) Reason (3_v)

Model	Rec	0.0	0.25	0.5	0.75	1.0
chat-bison	0/10	0/10	1/10	0/10	5/10	7/10
codechat-bison	0/10	0/10	0/10	1/10	2/10	1/10
codellama34b	0/10	0/10	0/10	0/10	0/10	0/10
gpt-3.5	0/10	0/10	0/10	0/10	0/10	0/10
gpt-4	0/10	0/10	0/10	0/10	0/10	0/10

(c) Accuracy (3_p)

Model	Rec	0.0	0.25	0.5	0.75	1.0
chat-bison	1/10	0/10	1/10	0/10	2/8	6/10
codechat-bison	0/10	0/10	0/10	0/10	1/9	1/10
codellama34b	0/10	0/10	1/10	0/10	2/10	1/10
gpt-3.5	0/10	0/10	0/10	0/10	0/10	0/10
gpt-4	0/10	1/10	1/10	1/10	1/10	1/10

(d) Reason (3_p)

in Tables 9 and 10.

Observations. Our results do not show a general trend of better performance with the increase in model temperature. Since increasing the temperature does not present a general improvement of results across our models, to prioritize result consistency we elected to use 0.0 as the 'temperature' value for the remaining of our experiments, and set 'top_p' to LLM specific default value.

4.3. Diversity of Prompts

In this part of investigation, we test the LLMs on their ability to detect vulnerabilities in the 48 hand-crafted code scenarios described in Section 3.4, by using the 17 prompts ranging over three categories and four prompting techniques, as described in Section 3.3. This experiment allows us to evaluate the capabilities of LLMs over a wide input spectrum and answer questions like (1) what kind of prompting techniques work best for the model, (2) whether emulating the multi-step reasoning process followed by human security experts improves performance, and (3) whether providing

extra information or examples helps LLMs in decision making?. Table 11 shows the results of this experiment based on the following three metrics:

(1) **Response Rate:** Measures how often the model provides an answer to a given input at all. E.g., for prompts ‘S5’ and ‘S6,’ ‘codechat-bison@001’ provides answers to 36 out of 48 inputs and for the rest it responds “I’m not able to help with that, as I’m only a language model. If you believe this is an error, please send us your feedback.”

$$ResponseRate = \frac{\#InputsAnswered}{TotalInputs}$$

(2) **Accuracy Rate:** Measures the correctness of the model’s response, regardless of the provided reasoning. E.g., for prompt ‘D2,’ ‘codechat-bison@001’ provides correct answers to 24 inputs out of the 48 answered inputs.

$$AccuracyRate = \frac{\#CorrectAnswers}{\#InputsAnswered}$$

(3) **Correct Reasoning Rate (CRR):** Evaluates how often the model’s correct answers also have the correct reasoning. E.g., for prompt ‘D2,’ ‘codechat-bison@001’ provides reasoning for 15 answers out of the 24 correct answers and out of those 15 reasonings 14 are correct.

$$CRR = \frac{\#CorrectAnswerswithCorrectReasoning}{\#ReasoningswithCorrectAnswers}$$

Best Prompts: Based on the above three metrics, we choose the best overall prompts for each model from four categories of prompts (described in Section 3.3) i.e., ZS - TO, ZS - RO, FS - TO, and FS - RO. We calculate a $Score_{prompt}$, which is the weighted sum of the three metrics where each metric is assigned an equal weight of 0.33. We then select the best prompt from each of the above defined four categories as the one that maximizes $Score_{prompt}$, as shown in Table 11.

Observations. ‘gpt-4’ performs the best among the tested LLMs, with a maximum accuracy of 89.5%. There is no prompt for which all LLMs perform consistently better, but instead they show different success for different types of prompts. GPT models and ‘codechat-bison’ perform better when prompted to follow a human-like step-by-step reasoning process (as shown in Figure 4) , i.e., R4, R6, and R2 prompts, respectively. ‘chat-bison’ performs best when assigned a ‘security expert’ role, while ‘codellama34b’ works best with the S1 prompt, which simply asks if the code snippet contains a certain vulnerability. While ‘gpt-4’ and ‘codellama34b’ show an increase in accuracy when provided with a vulnerability definition, compared to standard prompts, the same trend is not found in the other LLMs.

4.4. Faithful Reasoning

Faithful reasoning is the quality of an LLM to provide the right reasoning for the right answer or vice versa [50]. The more faithful an LLM’s reasoning is to its final answer, the more a user can trust its response. Table 11 shows that even when they provide the right response, LLMs sometimes provide the wrong reason for this decision. In this section, we further analyze the faithful reasoning of LLMs on their decisions from the experiment discussed in the previous

TABLE 11: Evaluation of five LLMs for detecting vulnerabilities across 48 hand-crafted code scenarios, over a range of prompting techniques. The green and red bars represent the count of scenarios with correct and incorrect responses for each LLM (i.e., *AccuracyRate*). A white circle marks scenarios with both correct answers and reasoning (*CRR*). Additionally, we highlight top-performing prompts for each technique: ZS-TO (S1), ZS-RO (S2), FS-TO (S3), and FS-RO (S4). The overall best prompt is shown with a red box.

M	Standard	Step-by-Step	Definition
	0 48	0 48	0 48
chat-bison	S1 22/48	R1 24/48	D1 23/48
	S2 23/48	R2 28/48	D2 24/48
	S3 22/48	R3 8/14	D3 34/48
	S4 26/48	R4 36/48	D4 30/48
	S5 31/48	R5 33/48	D5 30/48
	S6 37/48	R6 33/48	
codechat-bison	S1 26/48	R1 25/48	D1 27/48
	S2 25/48	R2 31/48	D2 24/48
	S3 25/48	R3 22/47	D3 22/36
	S4 24/48	R4 27/36	D4 23/36
	S5 20/36	R5 24/36	D5 22/36
	S6 21/36	R6 23/36	
codellama34b	S1 29/48	R1 25/48	D1 25/48
	S2 24/48	R2 20/46	D2 25/48
	S3 24/48	R3 24/48	D3 31/48
	S4 24/48	R4 23/48	D4 23/48
	S5 27/48	R5 24/48	D5 27/48
	S6 26/48	R6 24/48	
gpt-3.5	S1 26/48	R1 27/47	D1 26/48
	S2 26/48	R2 33/47	D2 29/48
	S3 28/48	R3 24/35	D3 32/48
	S4 28/48	R4 34/48	D4 31/48
	S5 30/48	R5 36/48	D5 31/47
	S6 33/48	R6 31/48	
gpt-4	S1 27/48	R1 34/48	D1 38/48
	S2 30/48	R2 41/48	D2 35/48
	S3 28/48	R3 31/42	D3 41/48
	S4 32/48	R4 41/48	D4 43/48
	S5 36/48	R5 43/48	D5 43/48
	S6 40/48	R6 43/48	

section, focusing on five aspects: (1) for how many cases does the LLM provide a reasoning for the presence of a vulnerability in a code snippet at all, (2) for how many correct answers the LLM also provides a correct reasoning, (3) for how many correct answers the LLM provides an incorrect reasoning, (4) for how many incorrect answers the LLM provides an incorrect and (5) for how many answers does the LLM provide the wrong answer, but a correct reasoning. Table 12 provides an overview of the results of this experiment.

Observations. While in the vast majority of cases the answer and reasoning for the tested LLMs align, every LLM presents cases where it provides the correct reasoning but this leads to a wrong answer (as shown in Figure 5). Similarly, we find cases where an LLM provides the right answer but its reasoning or root cause is not correct (as shown under ‘codechat-bison (1st Response)’ in Figure 3b). We also find that Google’s PaLM2 models have overall lower reasoning rate as they do not explain their decisions in

```

1 ...
2 void read_file(char* file_path) {
3     char* resolved_path = realpath(file_path, NULL);
4     if (resolved_path == NULL) {
5         printf("Error: Invalid Path\n");
6         return;
7     }
8     char* dir = "/Users/user1/";
9     /* safely creates full_path by concatenating
10      file_path with dir */
11     FILE *fp;
12     char *data = malloc(256);
13     fp = fopen(full_path, "r");
14     while (fgets(data, 256, fp) != NULL)
15     { /* processes file */ }
16 }

```

(a) CWE-476 (NULL-Pointer Dereference) 1_v: This code scenario sanitizes the user provided file path, opens file at that file path, and processes it. The code does not check for the NULL value of fopen in case an error is raised.

GPT-3.5 (Standard S1)

No, this code does not contain instances of the security vulnerability known as **NULL pointer dereference**.

GPT-3.5 (Step-by-Step R2)

1. Overview of the code:

The code defines a function called 'read_file' that takes a file path as input. It first resolves the absolute path it proceeds to open the file and read its contents

2. Identified sub-components that could lead to NULL pointer dereference:

- The 'realpath' function call could potentially return a NULL pointer
- The 'fopen' function call could return a NULL pointer

3. Detailed analysis of the identified sub-components:

- The 'realpath' function call - The 'realpath' function returns a NULL pointer if it fails to resolve the path the code prints an error message and returns without further execution
- The 'fopen' function call - **The code does not check if the 'fopen' function returns a NULL pointer** the subsequent 'fgets' function call will result in a NULL pointer dereference vulnerability.

4. Conclusion:

Based on the detailed analysis,..... **the NULL pointer dereference vulnerability is present in the given code.**

(b) GPT-3.5 Responses.

Figure 4: 'GPT-3.5' responses to standard 'S1' and security-expert like multi-step reasoning 'R2' for CWE-476 1_v code scenario.

many cases, while GPT models show comparatively higher reasoning rates, especially 'gpt-4' and 'codellama34b' provide a reason for every answer. Our findings suggest that, in certain cases, current LLMs' responses might not fully rely on faithful and accurate reasoning.

4.5. Evaluation Over Variety of Vulnerabilities

In this section, we focus on analyzing LLMs ability to correctly identify both vulnerable and patched code for different types of vulnerabilities, based on the eight CWEs that we used to build our hand-crafted dataset. Similar to Section 4.3, we find and use the best performing prompts for

TABLE 12: Faithfulness of LLMs. The Table shows the Reason Rate i.e., # scenarios for which LLM provides reasoning / # total scenarios answered by LLM (out of total 816 scenarios). Then it displays # of scenarios with correct answer and correct reasoning (■), # correct answer but incorrect reasoning (■), # incorrect answer and incorrect reasoning (■), and # incorrect answer but correct reasoning (■).

Model	Reas. Rate	Details
chat-bison	724 /782	
codechat-bison	680 /719	
codellama34b	814 /814	
gpt-3.5	788 /800	
gpt-4	810 /810	

chat-bison

Analysis:

b) The 'cmd_files' function validates the command for ';' character. But it **does not validate the command for other special characters like '|', '\$' or '&&'.** So, there is a possibility of command injection.

Decision: **the code is safe from command injection vulnerability.**

Figure 5: 'chat-bison@001' (PaLM2) response for CWE-77 3_v scenario (see Appendix Figure 11) using prompt 'D3' shows unfaithfulness between provided reasoning and final answer.

each CWE using $Score_{cwe}$, with equal weight to all factors, from four prompting categories. The results are summarized in Table 13.

Observations. Most models show poor performance in classifying the patched versions correctly, which makes these LLMs non-suitable for real-world cases as they will mostly flag safe code as vulnerable, causing many false alarms. We observe that few-shot prompting performs significantly better than zero-shot prompting for almost all models (p-value = 0.003), and role-oriented prompts perform slightly better than task-oriented prompts (p-value = 0.1). The reason for this is that assigning a role to the model grounds its knowledge for the given task and prevents it from hallucinating, which can be seen in the increase in reasoning score for role-oriented prompts. However, Table 13 shows that 'codechat-bison@001' does not provide answers for 'CWE-787' and 'CWE-416' for few-shot prompts.

4.6. Code Difficulty Levels

In this section, we investigate the capabilities of LLMs to handle different complexities of code. Similar to the previous sections, we find the best performing prompts for each difficulty level using $Score_{diff}$, with equal weight to all factors, from four prompting categories. Table 14 summarizes the results of this experiment.

Observations. LLMs generally perform better on the easy code scenarios, with limited exceptions (e.g., 'codechat-

TABLE 13: Evaluation of LLMs over a wide range of eight most critical vulnerabilities. Each bar represents count of correctly classified vulnerable (■ bar) and patched (□ bar) code scenarios, and each circle marks count of correctly reasoned vulnerable (white circle) and patched (black circle) code scenarios, out of total answered scenarios by each LLM.

		Best Prompts							
	Model	ZS - TO		ZS - RO		FS - TO		FS - RO	
		0 — 6	0 — 6	0 — 6	0 — 6	0 — 6	0 — 6	0 — 6	0 — 6
CWE-190	chat-bison	S1 1/6	R2 1/6	R6 1/6	S6 1/6				
	codechat-bison	S1 3/6	R2 5/6	D5 4/6	D4 4/6				
	codellama34b	S1 3/6	S2 3/6	D5 4/6	S6 3/6				
	gpt-3.5	R3 3/5	R2 5/6	S5 4/6	R4 4/6				
	gpt-4	R3 5/6	R2 6/6	S5 5/6	R5 6/6				
CWE-22	chat-bison	D1 4/6	S2 3/6	R6 5/6	R4 5/6				
	codechat-bison	R3 3/6	S2 3/6	R6 4/6	R4 4/6				
	codellama34b	S1 3/6	S2 3/6	R6 4/6	R5 4/6				
	gpt-3.5	D1 3/6	R2 5/6	D5 4/6	R4 4/6				
	gpt-4	R1 3/6	R2 5/6	R6 5/6	S6 5/6				
CWE-416	chat-bison	S1 3/6	S2 3/6	R6 4/6	R4 5/6				
	codechat-bison	S1 3/6	S4 4/6	X 0/0	X 0/0				
	codellama34b	S1 6/6	S2 3/6	S5 3/6	D3 5/6				
	gpt-3.5	S1 5/6	S3 5/6	S5 4/6	S6 4/6				
	gpt-4	D1 6/6	S4 6/6	R6 6/6	R4 6/6				
CWE-476	chat-bison	S1 4/6	R2 4/6	S5 3/6	S6 5/6				
	codechat-bison	D1 4/6	S4 4/6	S5 3/6	R4 5/6				
	codellama34b	S1 3/6	S2 3/6	S5 3/6	D3 4/6				
	gpt-3.5	R3 4/5	R2 5/6	R6 3/6	S6 6/6				
	gpt-4	R1 4/6	S4 6/6	R6 6/6	D3 6/6				
CWE-77	chat-bison	R1 5/6	S4 3/6	S5 6/6	R4 6/6				
	codechat-bison	S1 3/6	R2 5/6	R6 5/6	R4 6/6				
	codellama34b	S1 3/6	S2 3/6	D5 4/6	D3 5/6				
	gpt-3.5	D1 4/6	R2 4/6	R6 6/6	R4 6/6				
	gpt-4	S1 3/6	S2 3/6	R6 6/6	R5 6/6				
CWE-787	chat-bison	R1 4/6	R2 4/6	S5 3/6	S6 3/6				
	codechat-bison	S1 4/6	R2 4/6	X 0/0	X 0/0				
	codellama34b	S1 4/6	D2 4/6	S5 4/6	D3 4/6				
	gpt-3.5	R3 4/6	D3 4/6	R6 4/6	R4 5/6				
	gpt-4	D1 6/6	S2 6/6	D5 6/6	S6 5/6				
CWE-79	chat-bison	S1 2/6	R2 4/6	S5 6/6	S6 6/6				
	codechat-bison	S1 3/6	S2 3/6	R6 6/6	S6 6/6				
	codellama34b	S1 4/6	S2 3/6	S5 3/6	S6 3/6				
	gpt-3.5	D1 4/6	S3 4/6	S5 4/6	D4 4/6				
	gpt-4	R3 5/5	R2 6/6	R6 6/6	S6 6/6				
CWE-89	chat-bison	S1 4/6	S2 4/6	S5 3/6	S6 6/6				
	codechat-bison	S1 4/6	S3 4/6	S5 4/6	D3 5/6				
	codellama34b	S1 3/6	S2 3/6	S5 6/6	R5 4/6				
	gpt-3.5	S1 5/6	S2 5/6	S5 5/6	S6 5/6				
	gpt-4	S1 5/6	S2 5/6	S5 5/6	S6 5/6				

bison' correctly recognizing more medium than easy vulnerabilities in the FS - TO setting). By manually looking at the misclassified scenarios, we make two observations; (1) LLMs are not familiar with the safe practices of library functions, and (2) LLMs cannot handle complex multi-function and multi-variable data flow patterns. For example, in the CWE-89 (SQL Injection) '3_p' scenario, the code creates an SQL query and its parameters in one function 'create_query', and returns them to the 'login' function where they are passed to 'pymysql' as separate arguments. None of the LLMs were able to understand this flow (e.g., the response from 'gpt-4' is shown in Figure 6), as they mistakenly assume that the 'login' function only passes one argument to the 'execute' function. The LLMs also seem to be unaware that 'pymysql' itself sanitizes the output.

TABLE 14: Evaluation of LLMs over a Range of Code Difficulty Levels. (Same color coding as Table 13).

		Best Prompts							
	Model	ZS - TO		ZS - RO		FS - TO		FS - RO	
		0 — 16	0 — 16	0 — 16	0 — 16	0 — 16	0 — 16	0 — 16	0 — 16
Easy	chat-bison	S1 7/16	R2 10/16	R6 14/16	S6 15/16				
	codechat-bison	S1 10/16	R2 12/16	R6 8/12	R4 9/12				
	codellama34b	S1 10/16	D2 9/16	S5 10/16	D3 11/16				
	gpt-3.5	R3 11/13	R2 13/15	D5 13/16	R5 15/16				
	gpt-4	D1 13/16	R2 14/16	R6 15/16	R5 16/16				
Medium	chat-bison	R1 9/16	S2 8/16	R6 11/16	S6 12/16				
	codechat-bison	R3 8/16	R2 9/16	D5 10/12	D4 10/12				
	codellama34b	S1 9/16	S2 8/16	D5 11/16	D3 11/16				
	gpt-3.5	S1 9/16	S3 10/16	R6 10/16	R4 12/16				
	gpt-4	D1 12/16	R2 15/16	D5 15/16	S6 14/16				
Hard	chat-bison	D1 8/16	R2 10/16	D5 10/16	R4 13/16				
	codechat-bison	R3 8/16	R2 10/16	R6 7/12	R4 10/12				
	codellama34b	S1 10/16	S2 8/16	S5 8/16	S6 9/16				
	gpt-3.5	R1 9/16	R2 11/16	R6 10/16	R4 10/16				
	gpt-4	R1 12/16	R2 12/16	R6 14/16	D3 13/16				

```

1 def createQuery(username, password):
2     query_text = "SELECT * FROM users WHERE username = '%s'
3         AND password = '%s'"
4     parameters = (username, password)
5     query = query_text, parameters
6     return query
7
8 @app.route("/login")
9 def login():
10     username = request.form('username')
11     password = request.form('password')
12
13     db = pymysql.connect("localhost")
14     cursor = db.cursor()
15
16     query = createQuery(username, password)
17     cursor.execute(query)

```

(a) CWE-89 (SQL Injection) 3_p code scenario. This code is not vulnerable to SQL Injection as it passes the 'query' and 'parameters' separately to the 'pymysql' function.

GPT-4

The 'createQuery' function in this code is vulnerable to SQL injection. The function constructs an SQL query using the 'username' and 'password' inputs without sanitizing them. This means that if a user provides a string that includes SQL commands as their username or password, those commands will be executed when the query is run...

(b) GPT-4 response.

Figure 6: GPT-4 provides wrong answer and reasoning to CWE-89 (hard-level) 3_p code scenario.

4.7. Robustness to Code Augmentations

In this section we test the robustness of LLMs by testing them against the code augmentations described in Section 3.4. Our results are summarized in Table 6. For each input augmentation we show the change in accuracy and reasoning score as compared to the original non-augmented version of the input. For each LLM, we test each augmentation using three prompts: standard prompt 'S1,' and the best zero-shot (ZS) and few-shot (FS) prompts.⁷

7. Since we show in Sections 4.5 and 4.6 that role-oriented prompts work better than task-oriented ones, we do not run experiments on all four categories of prompts.

TABLE 15: Evaluation for Code-Level Augmentations. The tables show Δ_a (# of answers that are correct in non-augmented scenarios but incorrect in this specific augmentation case) and Δ_p (# of reasoning that are correct in non-augmented scenarios but incorrect in this specific augmentation case) for each code augmentation and for three prompts (standard ‘S1’, best zero-shot, and best few-shot) of each LLM.

M	PS	T1		T2		T3		T4		T5		T6		T7	
		Δ_a	Δ_p	Δ_a	Δ_p	Δ_a	Δ_p	Δ_a	Δ_p	Δ_a	Δ_p	Δ_a	Δ_p	Δ_a	Δ_p
c-bison	S1s	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12
	R2s	2/12	2/12	1/12	1/12	0/12	0/12	1/12	1/12	2/12	3/12	0/12	0/12	0/12	1/12
	S6s	2/12	3/12	2/12	2/12	2/12	4/12	1/12	3/12	2/12	2/12	2/12	2/12	2/12	1/12
cc-bison	S1s	0/12	2/12	0/12	3/12	0/12	3/12	0/12	0/12	0/12	2/12	0/12	2/12	0/12	1/12
	R2s	0/12	0/12	0/12	1/12	0/12	0/12	3/12	3/12	2/12	2/12	0/12	2/12	1/12	1/12
	R4s	0/12	0/12	0/12	0/12	0/12	0/12	1/12	1/12	0/12	0/12	1/12	1/12	0/12	0/12
c-llm34b	S1s	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12
	S1s	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12
	S5s	0/12	0/12	3/12	3/12	3/12	3/12	2/12	3/12	0/12	0/12	1/12	1/12	2/12	2/12
gpt-3.5	S1s	0/12	0/12	0/12	0/12	2/12	3/12	1/12	1/12	0/12	0/12	1/12	2/12	0/12	0/12
	R2s	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12
	R4s	1/12	1/12	1/12	1/12	1/12	1/12	1/12	1/12	2/12	2/12	0/12	0/12	1/12	1/12
gpt-4	S1s	0/12	0/12	0/12	2/12	0/12	2/12	0/12	0/12	0/12	0/12	0/12	1/12	0/12	0/12
	R2s	2/12	1/12	1/12	0/12	3/12	2/12	2/12	1/12	1/12	0/12	2/12	1/12	1/12	1/12
	R6s	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12

(a) Trivial Augmentations

M	PS	NT1		NT2		NT3		NT4		NT5		NT6	
		Δ_a	Δ_p	Δ_a	Δ_p	Δ_a	Δ_p	Δ_a	Δ_p	Δ_a	Δ_p	Δ_a	Δ_p
c-bison	S1s	0/12	0/12	1/12	0/12	8/12	7/12	0/12	1/12	0/9	2/9	0/9	1/9
	R2s	3/12	2/12	2/12	2/12	4/12	4/12	0/12	6/12	0/9	2/9	0/9	3/9
	S6s	0/12	0/12	5/12	5/12	8/12	8/12	0/12	0/12	4/9	4/9	2/9	1/9
cc-bison	S1s	0/12	2/12	3/12	1/12	9/12	9/12	1/12	4/12	1/9	4/9	1/9	0/9
	R2s	1/12	2/12	4/12	4/12	7/12	6/12	1/12	1/12	0/9	0/9	0/9	0/9
	R4s	0/12	0/12	5/12	6/12	1/12	1/12	0/12	0/12	6/9	6/9	0/9	0/9
c-llm34b	S1s	1/12	0/12	4/12	4/12	9/12	9/12	1/12	3/12	1/9	2/9	1/9	0/9
	S1s	1/12	0/12	4/12	4/12	9/12	9/12	1/12	5/12	1/9	1/9	1/9	0/9
	S5s	0/12	0/12	3/12	3/12	3/12	3/12	1/12	5/12	0/9	0/9	1/9	0/9
gpt-3.5	S1s	1/12	0/12	1/12	2/12	1/12	1/12	2/12	2/12	0/9	0/9	2/9	1/9
	R2s	0/12	0/12	2/12	2/12	0/12	0/12	2/12	2/12	3/9	3/9	0/9	0/9
	R4s	0/12	0/12	3/12	4/12	3/12	3/12	0/12	4/12	3/9	3/9	3/9	1/9
gpt-4	S1s	0/12	2/12	1/12	3/12	0/12	0/12	2/12	7/12	0/9	0/9	2/9	1/9
	R2s	0/12	0/12	0/12	0/12	3/12	3/12	0/12	2/12	0/9	0/9	0/9	1/9
	R6s	0/12	0/12	3/12	3/12	0/12	0/12	1/12	5/12	5/9	5/9	1/9	1/9

(b) Non-Trivial Augmentations

Observations. Table 15a shows that even trivial augmentations like the addition of whitespaces (Figure 7a) and new-line characters lead all LLMs to an incorrect answer and reasoning in some cases, and further breaks their chain-of-thought reasoning. Furthermore, changing function or variable names or the presence of unreachable code lead to incorrect answers. When looking at non-trivial augmentations, Table 15b shows that LLM performance is also affected by function and variable names, e.g., changing a variable name to ‘buffer’ in NT1 leads to the wrong detection of a buffer overflow and changing a function name to ‘non_vulnerable’ or to a safe function name increases the chances to be detected as non-vulnerable. Most importantly, LLMs present a bias towards library functions that are usually used for sanitization or are considered potentially vulnerable. E.g., all LLMs would declare the safe usage of ‘strcat’ in C as vulnerable, and unsafe uses of ‘strncat’ would be flagged as safe (Figure 7b). Similarly, the unsafe use of sanitizing library functions like ‘realpath’ in C or ‘escape’ in Python

chat-bison

The ‘dst_buf’ is allocated with a size of 4 * sizeof(char) * MAX_SIZE + 1. The ‘dst_index’ is incremented by 4 for each character in the ‘user_supplied_string’. So, the ‘dst_buf’ -- can hold 4 * MAX_SIZE characters. But the ‘user_supplied_string’ can have a length of up to 32 characters. So, the ‘dst_buf’ can be overwritten if the ‘user_supplied_string’ has a length of more than 32 characters. -- ++ the ‘dst_buf’ is allocated with enough space to store the encoded string. ++ So, the code is ++ not ++ vulnerable to out-of-bound write.

(a) Example of a complete change in ‘chat-bison’ decision by just adding whitespaces (T5) in code scenario CWE-787 2_v (shown in Figure 3a) after line 22.

GPT-4

the code is not safe from out-of-bounds write due to the **incorrect use of ‘strcat’** in the else branch. This could potentially lead to a buffer overflow.

the allocated memory for ‘dst_buf’ is 4 times ‘MAX_SIZE’ the code is **safe** from out-of-bound write or buffer overflow.

(b) Example of NT5 augmentation to CWE-787 2_v, where even the addition of safely used ‘strcat’ successfully confuses ‘gpt-4’ to classify the code as vulnerable merely on the basis of the presence of ‘strcat.’ However, the addition of ‘strncat’ leads to the classification of vulnerable code as safe.

Codellama34B

Yes, this code contains instances of the security vulnerability known as cross-site scripting (XSS). The ‘create_output’ function constructs an HTML string that includes user-provided data from the ‘day’ parameter. This data is not sanitized or escaped

No, this code does not contain instances of the security vulnerability known as cross-site scripting (XSS). The ‘escape’ function used in the ‘create_output’ function is a security measure to prevent XSS attacks by escaping any special characters in the ‘day’ parameter. code appears to be secure against XSS attack.

(c) Example of NT5 augmentation to CWE-79 2_o, where even an addition of an unsafe ‘escape’ function call makes ‘codellama34b’ believe that the code is safe.

Figure 7: Non-robustness in most capable LLMs responses. Red shows response for code scenario before augmentation and green is for after augmentation.

(Figure 7c) are detected as non-vulnerable. Our experiments show that there is no prompting technique that is completely robust as our robustness tests break even the best types of prompting techniques and chain-of-thought for all LLMs, leading to incorrect responses (17% of cases for GPT-4).

4.8. Real-World Cases

Finally, we investigate the ability of LLMs to identify real-world vulnerable code, by leveraging our CVE dataset (see Table 5) using the best prompts listed in Table 11. The results are summarized in Tables 16 and 17.

Observations. Overall, the evaluation with our real-world CVEs samples highlights that LLMs face challenges in detecting vulnerabilities in real-world projects, with all studied LLMs providing incorrect answers for several of our test cases. In addition to providing wrong answers for vulnerable code, LLMs frequently mistakenly identify patched examples as vulnerable, which would be particularly problematic if these models were used in production, as it would make the number of false positives skyrocket. We also observe that few-shot prompting does not work in case of real-world scenarios, likely because LLMs fail to extrapolate

TABLE 16: Evaluation on real-world CVEs for Linux and pjsip. This table shows results for both vulnerable and patched versions of every CVE, given by the best prompts of every LLM. ⊖ (no answer), ✓ (correct answer but wrong reasoning), ● (correct answer with correct reasoning), ✗ (wrong answer and no reasoning), and ✖ (wrong answer and no or wrong reasoning).

	Model	ZS - TO		ZS - RO		FS - TO		FS - RO	
		v	p	v	p	v	p	v	p
linux CVE-2023-40283	chat-bison	✖	✖	✖	✖	✖	✖	✖	✖
	codechat-bison	✓	✓	✖	✓	⊖	⊖	⊖	⊖
	codellama34b	✖	✖	✖	✖	⊖	⊖	⊖	⊖
	gpt-3.5	✓	✓	✓	✓	✖	✖	✖	✖
	gpt-4	✖	✖	✖	⊖	✖	✖	✖	✖
linux CVE-2023-42753	chat-bison	✖	✖	⊖	✖	⊖	✖	✖	✖
	codechat-bison	⊖	✖	⊖	⊖	⊖	⊖	✓	✓
	codellama34b	✖	⊖	✖	✖	⊖	✖	✖	✖
	gpt-3.5	✓	⊖	⊖	✓	✖	✖	✖	✖
	gpt-4	✖	✖	✖	✓	✖	✖	✖	✖
linux CVE-2023-42754	chat-bison	✓	✓	✖	✖	✖	✖	✖	✖
	codechat-bison	✓	✓	✖	✖	✖	✖	✖	✖
	codellama34b	⊖	✓	✖	✖	✓	✖	✓	✖
	gpt-3.5	⊖	⊖	✓	✖	✖	✖	⊖	⊖
	gpt-4	✖	✖	✖	✓	✖	⊖	✖	⊖
linux CVE-2023-48683	chat-bison	✖	✖	✖	✖	✖	✖	✖	✖
	codechat-bison	✖	✖	✖	✖	⊖	⊖	⊖	⊖
	codellama34b	✖	✖	⊖	⊖	✓	✓	⊖	⊖
	gpt-3.5	⊖	⊖	✓	✖	✖	✖	✖	✖
	gpt-4	✖	✖	✖	⊖	✖	✖	✖	✖
linux CVE-2023-48871	chat-bison	✖	✖	✓	✖	✖	✖	✓	✓
	codechat-bison	✓	✓	✓	✓	⊖	⊖	⊖	⊖
	codellama34b	✖	✖	✖	✖	⊖	✖	✖	✖
	gpt-3.5	⊖	⊖	⊖	✖	✖	✖	⊖	⊖
	gpt-4	✖	✖	⊖	✖	✖	✖	✓	✖
pjsip CVE-2023-27585	chat-bison	✖	✖	✖	✖	✖	⊖	✖	⊖
	codechat-bison	✖	✖	✖	✖	⊖	⊖	⊖	⊖
	codellama34b	⊖	✖	✖	✖	✖	✖	✖	✖
	gpt-3.5	✖	✖	✓	✖	✖	✖	✖	✖
	gpt-4	✖	✖	✓	⊖	✖	✖	✖	✓

information from the provided examples (despite being from the same CWEs) and apply it to other software codebases. At the same time, we find that the zero-shot role-oriented prompt ‘R2’ shows relatively better performance for all LLMs, which indicates that grounding LLM’s role as ‘security expert’ and providing them explicit guidelines to follow a human-like multi-step vulnerability detection process can improve performance, but is still insufficient for real-world deployment.

5. Discussion

SecLLMHolmes allows users to evaluate any chat-based LLM for its ability to identify software vulnerabilities. Further, we have publicly released our framework, enabling the community to evaluate LLMs released in the future. For example, researchers will be able to compare performance between different releases of an LLM, or study if changing properties like model architecture or number of parameters improves their ability to detect vulnerabilities.⁸

8. We include these case studies for ‘codellama7B’, ‘codellama13B’, and ‘starchat-beta’ in tables in Appendix

TABLE 17: Evaluation on Real-World CVEs for gpac and libtiff.

	Model	ZS - TO		ZS - RO		FS - TO		FS - RO	
		v	p	v	p	v	p	v	p
gpac CVE-2023-1452	chat-bison	✓	✓	⊖	✓	✖	✓	✓	✓
	codechat-bison	✓	✓	✓	⊖	⊖	⊖	⊖	⊖
	codellama34b	✖	⊖	⊖	⊖	✖	✓	⊖	⊖
	gpt-3.5	⊖	⊖	✓	✓	✖	✖	⊖	✖
	gpt-4	✖	✖	✓	✓	✓	✖	✓	✓
gpac CVE-2023-23143	chat-bison	✖	✖	✓	✖	✖	✖	✓	✓
	codechat-bison	✖	✖	✓	✓	⊖	⊖	⊖	⊖
	codellama34b	✖	✖	✖	✖	✓	✓	✖	✖
	gpt-3.5	⊖	⊖	✓	✓	✖	✖	✓	✖
	gpt-4	✖	✖	✖	✖	✓	✖	✖	✖
gpac CVE-2023-23144	chat-bison	✖	✖	✖	✖	✖	✓	✖	✖
	codechat-bison	✓	✓	✓	✓	⊖	⊖	⊖	✓
	codellama34b	✓	✓	✖	✓	✓	✓	✓	✓
	gpt-3.5	✖	✓	✖	✓	✖	✖	⊖	✖
	gpt-4	✖	✖	✖	✓	✖	✖	✖	⊖
gpac CVE-2023-3012	chat-bison	✓	✓	✖	✖	✓	✓	✖	✖
	codechat-bison	✓	✓	✖	✖	✓	✓	✖	✖
	codellama34b	✓	✓	✖	✖	✓	✓	⊖	⊖
	gpt-3.5	✖	✖	✓	✖	✖	✖	✖	✖
	gpt-4	✖	✖	✓	✓	✓	✓	✓	✓
libtiff CVE-2023-26966	chat-bison	✖	✖	✖	✖	✖	✖	✖	✖
	codechat-bison	✖	✖	✖	✖	⊖	⊖	⊖	⊖
	codellama34b	✖	✖	✖	✓	✖	✖	✖	⊖
	gpt-3.5	⊖	⊖	⊖	⊖	✖	✖	✖	✓
	gpt-4	✖	⊖	⊖	⊖	✓	✖	✓	✖
libtiff CVE-2023-2908	chat-bison	✓	✓	✓	✓	✖	✖	✖	✖
	codechat-bison	✖	✖	✖	⊖	⊖	⊖	✓	✓
	codellama34b	✓	✓	✖	⊖	✖	✖	✖	✖
	gpt-3.5	✖	✖	✖	✖	✓	✖	✖	✖
	gpt-4	✖	✖	✖	✖	✓	✓	✓	✓
libtiff CVE-2023-3316	chat-bison	✓	✓	✖	✖	✖	✖	✓	✖
	codechat-bison	✓	✓	✖	✖	✖	✖	✖	✖
	codellama34b	✖	✖	✖	✖	✓	✓	✓	✖
	gpt-3.5	✖	⊖	✓	✓	✖	✖	✖	✖
	gpt-4	✖	✖	✓	✓	✓	✓	✓	✓
libtiff CVE-2023-40745	chat-bison	✖	✓	✓	⊖	✖	✖	✖	✖
	codechat-bison	✖	✖	⊖	⊖	✖	✖	⊖	⊖
	codellama34b	✓	✓	⊖	⊖	✓	✓	✖	✖
	gpt-3.5	✓	⊖	✖	✓	⊖	✖	⊖	⊖
	gpt-4	✓	✓	✓	✓	✖	✖	✓	✖
libtiff CVE-2023-41175	chat-bison	✖	✖	✖	✓	✖	✖	✖	⊖
	codechat-bison	✖	✓	⊖	✓	✖	✓	⊖	✓
	codellama34b	✓	✖	⊖	✓	✓	✓	⊖	⊖
	gpt-3.5	⊖	✖	✓	✖	✖	✖	✖	✖
	gpt-4	✓	✓	✓	✖	✖	✖	✖	✖

AI companies are taking steps to address some of the issues highlighted in this work. For example, the latest release of ‘GPT-4 Turbo (preview)’ introduces the use of a ‘seed’ during inference to enable deterministic output. While a step in the right direction to ensure reliable output, this approach still presents the problem that different seeds might produce different answers for the same input.

Limitations. As any research project, our work presents some limitations. In the following, we discuss them in detail.

Answer and Reason Extraction. We use GPT-4 to parse the LLM output and extract the final answer and reasoning, using a prompt that requires GPT-4 to answer in a given format (as shown in Figure 8 in the Appendix), otherwise further steps of our analysis would fail. We manually analyze 100

extracted answers and reasonings by GPT-4 and only two were not answered in the given format.⁹

Knowledge Cut-Off. To evaluate newer LLMs, researchers might have to identify CVEs that were released after their knowledge cut-off, to avoid biases in the results. Our framework is modular and allows to add new ground truth data to the evaluation pipeline.

Reasoning Score. We use a combination of three metrics (Rouge, Cosine Similarity, and GPT-4) and select the majority decision to the chance of false positives. However, if two metrics agree on a wrong output, our approach would still report a false positive. Out of 100 manually selected examples, we find that this happened 7 times.

Representativeness of Code Scenarios. While we developed a wide numbers of code scenarios, there are many aspects of difficulty levels and code augmentations as well as many languages and vulnerabilities that were not considered. Our framework can be easily extended in the future to include additional code scenarios.

6. Conclusion

This work presents the first scalable and fully automated framework to evaluate the efficiency and reasoning capabilities of chat-based LLMs across eight distinct dimensions for the task of vulnerability detection. We performed an evaluation of state-of-the-art LLMs using this framework, showing that they are currently unreliable at this task and will answer wrongly when asked to identify vulnerabilities in source code. Based on these results, we conclude that state-of-the-art LLMs are not yet ready to be used for vulnerability detection and urge future research to address and resolve the highlighted issues. Our framework and benchmarks will be a useful tool for the community to evaluate the progress of future LLM versions in vulnerability detection.

Acknowledgments

We would like to thank Syed Qasim and Pujan Paudel for their help in generating ground-truth reasoning for the code scenarios. This work was supported by the Red Hat Collaboratory and by the NSF under grants CNS-1942610 and CNS-2127232. Any opinions, findings, and conclusions, or recommendations expressed are those of the authors and do not necessarily reflect the views of the sponsors.

References

- [1] M. Chen, J. Twarek, H. Jun, Q. Yuan, H. Ponde de Oliveira Pinto, J. Kaplan, H. Edwards, Y. Burda, N. Joseph, G. Brockman, A. Ray, R. Puri, G. Krueger, M. Petrov, H. Khlaaf, G. Sastry, P. Mishkin, B. Chan, S. Gray, N. Ryder, M. Pavlov, A. Power, L. Kaiser, M. Bavarian, C. Winter, P. Tillet, F. Petroski Such, D. Cummings, M. Plappert, F. Chantzis, E. Barnes, A. Herbert-Voss, W. Hebggen Guss, A. Nichol, A. Paino, N. Tezak, J. Tang, I. Babuschkin, S. Balaji, S. Jain, W. Saunders, C. Hesse, A. N. Carr, J. Leike, J. Achiam, V. Misra, E. Morikawa, and Radford, "Evaluating Large Language Models Trained on Code," *arXiv e-prints*, p. arXiv:2107.03374, Jul. 2021.
- [2] R. Anil, A. M. Dai, O. Firat, M. Johnson, and D. Lepikhin, "Palm 2 technical report," 2023.
- [3] B. Rozière, J. Gehring, F. Gloeckle, S. Sootla, I. Gat, X. E. Tan, Y. Adi, J. Liu, T. Remez, J. Rapin, A. Kozhevnikov, I. Evtimov, J. Bitton, M. Bhatt, C. Canton Ferrer, A. Grattafiori, W. Xiong, A. Défossez, J. Copet, F. Azhar, H. Touvron, L. Martin, N. Usunier, T. Scialom, and G. Synnaeve, "Code Llama: Open Foundation Models for Code," *arXiv e-prints*, p. arXiv:2308.12950, Aug. 2023.
- [4] R. Li, L. Ben Allal, Y. Zi, N. Muennighoff, D. Kocetkov, C. Mou, M. Marone, C. Akiki, J. Li, J. Chim, Q. Liu, E. Zheltonozhskii, T. Y. Zhuo, T. Wang, O. Dehaene, M. Davaadorj, J. Lamy-Poirier, J. Monteiro, O. Shliazhko, N. Gontier, N. Meade, A. Zebaze, M.-H. Yee, L. K. Umapathi, J. Zhu, B. Lipkin, M. Oblokulov, Z. Wang, R. Murthy, J. Stillerman, S. Sankalp Patel, D. Abulkhanov, M. Zocca, M. Dey, Z. Zhang, N. Fahmy, U. Bhattacharyya, W. Yu, S. Singh, S. Luccioni, P. Villegas, M. Kunakov, F. Zhdanov, M. Romero, T. Lee, N. Timor, and J. Ding, "StarCoder: may the source be with you!" *arXiv e-prints*, p. arXiv:2305.06161, May 2023.
- [5] OpenAI, "Gpt-4 technical report," 2023.
- [6] "Gitlab 2022 survey." <https://about.gitlab.com/blog/2022/08/23/gitlab-2022-global-devsecops-survey-security-is-the-top-concern-investment/#more-work-to-do>, accessed on: 2023-07-10.
- [7] H. Pearce, B. Tan, B. Ahmad, R. Karri, and B. Dolan-Gavitt, "Examining zero-shot vulnerability repair with large language models," in *IEEE Symposium on Security and Privacy*, 2023.
- [8] H. Pearce, B. Ahmad, B. Tan, B. Dolan-Gavitt, and R. Karri, "Asleep at the keyboard? assessing the security of github copilot's code contributions," in *IEEE Symposium on Security and Privacy*, 2022.
- [9] N. Perry, M. Srivastava, D. Kumar, and D. Boneh, "Do users write more insecure code with ai assistants?" in *Proceedings of ACM SIGSAC Conference on Computer and Communications Security*, 2023.
- [10] "Diffblue cover: Autonomous java unit test writing with ai for code," <https://www.diffblue.com/products/>, accessed on: 2023-07-10.
- [11] J. Wei, X. Wang, D. Schuurmans, M. Bosma, B. Ichter, F. Xia, E. Chi, Q. V. Le, and D. Zhou, "Chain-of-thought prompting elicits reasoning in large language models," in *Advances in Neural Information Processing Systems*, 2022.
- [12] A. Vaswani, N. Shazeer, N. Parmar, J. Uszkoreit, L. Jones, A. N. Gomez, L. u. Kaiser, and I. Polosukhin, "Attention is all you need," in *Advances in Neural Information Processing Systems*, 2017.
- [13] J. Wei, Y. Tay, R. Bommasani, C. Raffel, B. Zoph, S. Borgeaud, D. Yogatama, M. Bosma, D. Zhou, D. Metzler, E. H. Chi, T. Hashimoto, O. Vinyals, P. Liang, J. Dean, and W. Fedus, "Emergent abilities of large language models," *Transactions on Machine Learning Research*, 2022.
- [14] T. Brown, B. Mann, N. Ryder, M. Subbiah, J. D. Kaplan, P. Dhariwal, A. Neelakantan, P. Shyam, G. Sastry, A. Askell, S. Agarwal, A. Herbert-Voss, G. Krueger, T. Henighan, R. Child, A. Ramesh, D. Ziegler, J. Wu, C. Winter, C. Hesse, M. Chen, E. Sigler, M. Litwin, S. Gray, B. Chess, J. Clark, and Berner, "Language models are few-shot learners," in *Advances in Neural Information Processing Systems*, 2020.
- [15] "OWASP List." https://owasp.org/www-community/Source_Code_Analysis_Tools, accessed on: 2023-07-10.
- [16] F. Yamaguchi, N. Golde, D. Arp, and K. Rieck, "Modeling and discovering vulnerabilities with code property graphs," in *IEEE Symposium on Security and Privacy*, 2014.
- [17] Y. Mirsky, G. Macon, M. Brown, C. Yagemann, M. Pruett, E. Downing, S. Mertoguno, and W. Lee, "VulChecker: Graph-based vulnerability localization in source code," in *32nd USENIX Security Symposium*, 2023.

9. We note that using the newest 'GPT-4 Turbo,' which provides responses in json format, could eliminate even these two anomalies.

- [18] Z. Li, D. Zou, S. Xu, X. Ou, H. Jin, S. Wang, Z. Deng, and Y. Zhong, "Vuldeepecker: A deep learning-based system for vulnerability detection," *Proceedings of Network and Distributed System Security Symposium*, 2018.
- [19] G. Lin, J. Zhang, W. Luo, L. Pan, and Y. Xiang, "Poster: Vulnerability discovery with function representation learning from unlabeled projects," in *Proceedings of ACM SIGSAC Conference on Computer and Communications Security*, 2017.
- [20] Z. Li, D. Zou, S. Xu, H. Jin, Y. Zhu, and Z. Chen, "Sysevr: A framework for using deep learning to detect software vulnerabilities," *IEEE Transactions on Dependable and Secure Computing*, 2022.
- [21] D. Guo, S. Lu, N. Duan, Y. Wang, M. Zhou, and J. Yin, "UniXcoder: Unified cross-modal pre-training for code representation," in *Proceedings of the 60th Annual Meeting of the Association for Computational Linguistics*, May 2022.
- [22] H. Hanif and S. Maffei, "Vulberta: Simplified source code pre-training for vulnerability detection," in *International Joint Conference on Neural Networks (IJCNN)*, 2022.
- [23] L. Phan, H. Tran, D. Le, H. Nguyen, J. Annibal, A. Peltekian, and Y. Ye, "CoText: Multi-task learning with code-text transformer," in *Proceedings of the 1st Workshop on Natural Language Processing for Programming (NLP4Prog)*, 2021.
- [24] "Pysa." <https://engineering.fb.com/2020/08/07/security/pysa/>, accessed on: 2023-07-10.
- [25] "Bandit." <https://bandit.readthedocs.io/en/latest/>, accessed on: 2023-07-10.
- [26] "Cppcheck." <https://cppcheck.sourceforge.io/>, accessed on: 2023-07-10.
- [27] "Infer." <https://fbinfer.com/>, accessed on: 2023-07-10.
- [28] G. Grieco, G. L. Grinblat, L. Uzal, S. Rawat, J. Feist, and L. Mounier, "Toward large-scale vulnerability discovery using machine learning," 2016.
- [29] D. Arp, E. Quiring, F. Pendlebury, A. Warnecke, F. Pierazzi, C. Wressneger, L. Cavallaro, and K. Rieck, "Dos and don'ts of machine learning in computer security," in *31st USENIX Security Symposium*, 2022.
- [30] N. Risse and M. Böhme, "Limits of Machine Learning for Automatic Vulnerability Detection," *arXiv e-prints*, p. arXiv:2306.17193, Jun. 2023.
- [31] W. Ahmad, S. Chakraborty, B. Ray, and K.-W. Chang, "Unified pre-training for program understanding and generation," in *Proceedings of Conference of the North American Chapter of the Association for Computational Linguistics: Human Language Technologies*, 2021.
- [32] "Microsoft codexglue leaderboard." <https://microsoft.github.io/CodeXGLUE/>, accessed on: 2023-07-10.
- [33] Y. Zhou, S. Liu, J. Siow, X. Du, and Y. Liu, "Devign: Effective vulnerability identification by learning comprehensive program semantics via graph neural networks," in *Advances in Neural Information Processing Systems*, 2019.
- [34] C. Thapa, S. I. Jang, M. E. Ahmed, S. Camtepe, J. Pieprzyk, and S. Nepal, "Transformer-based language models for software vulnerability detection," in *Proceedings of the 38th Annual Computer Security Applications Conference*, 2022.
- [35] "Best practices for prompt engineering with OpenAI API," <https://help.openai.com/en/articles/6654000-best-practices-for-prompt-engineering-with-openai-api>, accessed on: 2023-07-10.
- [36] "Introduction to prompt design," https://developers.generativeai.google/guide/prompt_best_practices, accessed on: 2023-07-10.
- [37] T. Kojima, S. S. Gu, M. Reid, Y. Matsuo, and Y. Iwasawa, "Large language models are zero-shot reasoners," in *Advances in Neural Information Processing Systems*, 2022, pp. 22 199–22 213.
- [38] M. Nye, A. Andreassen, G. Gur-Ari, H. W. Michalewski, J. Austin, D. Bieber, D. M. Dohan, A. Lewkowycz, M. P. Bosma, D. Luan, C. Sutton, and A. Odena, "Show your work: Scratchpads for intermediate computation with language models," 2021, <https://arxiv.org/abs/2112.00114>.
- [39] D. Votipka, R. Stevens, E. Redmiles, J. Hu, and M. Mazurek, "Hackers vs. testers: A comparison of software vulnerability discovery processes," in *IEEE Symposium on Security and Privacy*, 2018.
- [40] D. Votipka, S. Rabin, K. Micinski, J. S. Foster, and M. L. Mazurek, "An observational investigation of reverse Engineers' processes," in *29th USENIX Security Symposium*, 2020.
- [41] "MITRE Top 25 Most Dangerous Software Weaknesses." <https://cwe.mitre.org/data/definitions/1387.html>, accessed on: 2023-07-10.
- [42] R. Russell, L. Kim, L. Hamilton, T. Lazovich, J. Harer, O. Ozdemir, P. Ellingwood, and M. McConley, "Automated vulnerability detection in source code using deep representation learning," in *17th IEEE International Conference on Machine Learning and Applications (ICMLA)*, 2018.
- [43] A. Rahman, C. Parnin, and L. Williams, "The seven sins: Security smells in infrastructure as code scripts," in *IEEE/ACM 41st International Conference on Software Engineering (ICSE)*, 2019.
- [44] K. Zhu, J. Wang, J. Zhou, Z. Wang, H. Chen, Y. Wang, L. Yang, W. Ye, Y. Zhang, N. Zhenqiang Gong, and X. Xie, "PromptBench: Towards Evaluating the Robustness of Large Language Models on Adversarial Prompts," *arXiv e-prints*, p. arXiv:2306.04528, 2023.
- [45] C. Li, J. Wang, Y. Zhang, K. Zhu, W. Hou, J. Lian, F. Luo, Q. Yang, and X. Xie, "Large Language Models Understand and Can be Enhanced by Emotional Stimuli," *arXiv e-prints*, p. arXiv:2307.11760, 2023.
- [46] J. L. Fleiss, B. Levin, and M. C. Paik, *Statistical methods for rates and proportions*. Wiley-Interscience, 2003.
- [47] C. Y. Lin, "ROUGE: A package for automatic evaluation of summaries." Association for Computational Linguistics, Jul. 2004.
- [48] "Cheat sheet: Mastering temperature and top_p in chatgpt api (a few tips and tricks on controlling the creativity/deterministic output of prompt responses.)," <https://community.openai.com/t/cheat-sheet-mastering-temperature-and-top-p-in-chatgpt-api-a-few-tips-and-tricks-on-controlling-the-creativity-deterministic-output-of-prompt-responses/172683/1>.
- [49] "OpenAI Chat Completion API Reference," <https://platform.openai.com/docs/api-reference/completions/create>, accessed on: 2023-07-10.
- [50] A. Creswell and M. Shanahan, "Faithful Reasoning Using Large Language Models," *arXiv e-prints*, p. arXiv:2208.14271, Aug. 2022.

Appendix A. Examples of Code Difficulty Levels

Easy: CWE-22 '1_v' (see Figure 9a) takes a file path as an input, which is then concatenated with an absolute directory path, and then the file is read and displayed on the console. The file path provided by the user is not sanitized, leading to a directory traversal vulnerability.

Medium: CWE-22 '2_v' (see Figure 9b) takes four inputs: file path, flag, data, and directory path (set using an environment variable). Based on the flag, data and file are processed. The program also calls the 'realpath' function to sanitize the input, but only applies it to the directory path, leaving the file path vulnerable to directory traversal.

Hard: CWE-22 '3_v' (see Figure 9c) contains two functions: 'resolve_path' that takes in a path and replaces all white

You are a helpful assistant who extracts answer whether an instance of vulnerability is present or not and its reason 'why' from the given text in the following format:
 Answer: ...
 Reason: ...

You must follow these rules while extracting information:

1. As a final decision or answer, does the text state that the code contains a security vulnerability known as <X>? (Answer yes or no or n/a, incase the text does not provide a definite answer)
2. If the text does not state the reason 'why' an instance of vulnerability is present or not then just write 'n/a' in reason.
3. If the answer in 1 is 'n/a' then just write 'n/a' in reason.
4. Only if 2 and 3 are not true then briefly describe the reasons mentioned in the text that state 'why' the code does or does not contain a security vulnerability known as <X>. Max word limit for reason is 100 words. Write in terms of code, e.g., 'The code/program/function ...'

Figure 8: Extraction Prompt P_e

spaces with hyphens, and 'print_file' that takes in the directory path from an environment variable and the file path from the user, concatenates them and calls 'resolve_path' on it. The 'resolve_path' function call in 'print_file' semantically appears to be sanitizing the given path, but actually it fails in doing so.

Appendix B. Robustness to Code Augmentations

A1: In this case, we design 12 CWE scenarios for the top two vulnerabilities in C i.e., CWE-787 (out-of-bound write) and CWE-416 (use-after-free) and replace the name of the variables with 'buffer' and ask the model to analyze the code for 'out-of-bound write / buffer overflow'.

A2: In this case, we select 12 patched versions of CWE-scenarios from the four most dangerous classes of vulnerabilities i.e., CWE-787 (C), CWE-79 (Py), CWE-89 (Py), and CWE-416 (C), and change the names of functions to 'vulnerable_func'.

A3: Opposite to 'A2', in this case, we select 12 vulnerable versions of CWE-scenarios from the same four classes of vulnerabilities and change the names of functions to 'non_vulnerable_func'.

A4: In this case, we safely add 'strcpy' and 'strcat' library functions, which are famous to be vulnerable but these are only vulnerable if they are not used properly, into 12 manually crafted code scenarios of CWE-787 and CWE-416.

A5: Opposite to 'A4', we add library functions which are commonly used to sanitize inputs. We add 'realpath', which is used to sanitize input file path and prevents path traversal attack, to three vulnerable CWE-22 scenarios. For python, we add 'escape', which is used to sanitize the use input for any scripts and prevents cross-site scripting attack, to three vulnerable CWE-79 scenarios. Finally we add 'strncat' and 'strncpy', which are considered safer functions to prevent out-of-bound write, to three vulnerable CWE-787 scenarios.

A6: In this case, we add respective '#define' expressions (as shown in figure 10) to 9 CWE scenarios from CWE-77, CWE-22, and CWE-787.

TABLE 18: Evaluation Output Consistency at Recommended Temperature (Ext. Table 7).

(a) CWE-787

	S1		S2		S3		S4		S5		S6	
Models	2 _v	2 _p	2 _v	2 _p	2 _v	2 _p	2 _v	2 _p	2 _v	2 _p	2 _v	2 _p
codellama7b	10/10	0/10	10/10	0/10	10/10	0/10	10/10	0/10	2/10	7/10	10/10	0/10
codellama13b	10/10	0/10	10/10	0/10	10/10	0/10	10/10	0/10	10/10	0/10	5/10	5/10
starchat	10/10	0/10	10/10	0/10	10/10	0/10	2/10	5/10	10/10	0/10	3/10	6/10

(b) CWE-89

	S1		S2		S3		S4		S5		S6	
Models	2 _v	2 _p	2 _v	2 _p	2 _v	2 _p	2 _v	2 _p	2 _v	2 _p	2 _v	2 _p
codellama7b	10/10	0/10	10/10	0/10	10/10	0/10	10/10	0/10	10/10	0/10	10/10	4/10
codellama13b	10/10	0/10	10/10	0/10	10/10	0/10	10/10	0/10	10/10	10/10	10/10	0/10
starchat	10/10	0/10	10/10	0/10	10/10	0/10	8/10	4/10	10/10	0/10	7/10	0/10

TABLE 19: Evaluation Output Consistency at Temperature = 0.0 (Ext. Table 8).

(a) CWE-787

	S1		S2		S3		S4		S5		S6	
Models	2 _v	2 _p	2 _v	2 _p	2 _v	2 _p	2 _v	2 _p	2 _v	2 _p	2 _v	2 _p
codellama7b	10/10	0/10	10/10	0/10	10/10	0/10	10/10	0/10	0/10	10/10	10/10	0/10
codellama13b	10/10	0/10	10/10	0/10	10/10	0/10	10/10	0/10	10/10	0/10	0/10	10/10
starchat	10/10	0/10	10/10	0/10	10/10	0/10	0/10	10/10	10/10	0/10	0/10	3/10

(b) CWE-89

	S1		S2		S3		S4		S5		S6	
Models	2 _v	2 _p	2 _v	2 _p	2 _v	2 _p	2 _v	2 _p	2 _v	2 _p	2 _v	2 _p
codellama7b	10/10	0/10	10/10	0/10	10/10	0/10	10/10	0/10	10/10	0/10	10/10	8/10
codellama13b	10/10	0/10	10/10	0/10	10/10	0/10	10/10	0/10	10/10	10/10	10/10	0/10
starchat	10/10	0/10	10/10	0/10	10/10	0/10	10/10	0/10	10/10	0/10	10/10	0/10

TABLE 20: Evaluation Over a Range of Temperature Values (CWE-787) (Ext. Table 9).

Model	Rec	0.0	0.25	0.5	0.75	1.0
codellama7b	10/10	10/10	10/10	10/10	10/10	9/10
codellama13b	10/10	10/10	10/10	10/10	9/10	10/10
starchat	10/10	10/10	8/10	7/10	8/10	7/9

(a) Accuracy (3_v)

Model	Rec	0.0	0.25	0.5	0.75	1.0
codellama7b	10/10	10/10	10/10	10/10	10/10	9/10
codellama13b	10/10	10/10	10/10	10/10	10/10	10/10
starchat	10/10	10/10	8/10	7/10	8/10	7/9

(b) Reason (3_v)

Model	Rec	0.0	0.25	0.5	0.75	1.0
codellama7b	0/10	0/10	0/10	0/10	0/10	0/10
codellama13b	0/10	0/10	0/10	0/10	0/10	0/10
starchat	0/10	0/10	0/10	2/10	1/10	1/10

(c) Accuracy (3_p)

Model	Rec	0.0	0.25	0.5	0.75	1.0
codellama7b	2/10	0/10	3/10	1/10	1/10	0/10
codellama13b	0/10	0/10	0/10	0/10	2/10	0/10
starchat	3/10	0/10	1/10	2/10	4/10	1/10

(d) Reason (3_p)

TABLE 21: Evaluation Over a Range of Temperature Values (CWE-89) (Ext. Table 10).

Model	Rec	0.0	0.25	0.5	0.75	1.0
codellama7b	10/10	10/10	10/10	10/10	10/10	10/10
codellama13b	10/10	10/10	10/10	9/10	10/10	10/10
starchat	7/10	0/10	6/10	6/9	9/9	7/10

(a) Accuracy (3_v)

Model	Rec	0.0	0.25	0.5	0.75	1.0
codellama7b	10/10	10/10	10/10	10/10	10/10	10/10
codellama13b	10/10	10/10	10/10	9/10	10/10	10/10
starchat	7/10	0/10	6/10	5/9	9/9	7/10

(b) Reason (3_v)

Model	Rec	0.0	0.25	0.5	0.75	1.0
codellama7b	0/10	0/10	0/10	0/10	0/10	0/10
codellama13b	0/10	0/10	0/10	0/10	1/10	1/10
starchat	4/10	0/10	2/8	4/10	1/9	2/9

(c) Accuracy (3_p)

Model	Rec	0.0	0.25	0.5	0.75	1.0
codellama7b	1/10	7/10	5/10	2/10	2/10	2/10
codellama13b	1/10	0/10	3/10	2/10	1/10	3/10
starchat	3/10	0/10	3/8	4/10	1/9	2/9

(d) Reason (3_p)

TABLE 22: Evaluation Diversity of Prompts (Ext. Table 11).

M	Standard	Step-by-Step	Definition
	0 — 48	0 — 48	0 — 48
codellama7b	S1	R1	D1
	S2	R2	D2
	S3	R3	D3
	S4	R4	D4
	S5	R5	D5
	S6	R6	
codellama13b	S1	R1	D1
	S2	R2	D2
	S3	R3	D3
	S4	R4	D4
	S5	R5	D5
	S6	R6	
starchat	S1	R1	D1
	S2	R2	D2
	S3	R3	D3
	S4	R4	D4
	S5	R5	D5
	S6	R6	

TABLE 23: Faithfulness of LLMs (Ext. Table 12).

Model	Reas. Rate	Details
codellama7b	814 /815	381 35 372 26 /814
codellama13b	815 /816	391 34 359 31 /815
starchat	809 /811	398 26 367 18 /809

TABLE 24: Evaluation range of vulnerabilities (Ext. Table 13).

Best Prompts				
Model	ZS - TO	ZS - RO	FS - TO	FS - RO
	0 — 6	0 — 6	0 — 6	0 — 6
CWE-190	codellama13b S1	S2	R6	D3
	codellama7b S1	D2	S5	S6
	starchat S1	S2	R6	S6
CWE-22	codellama13b S1	S2	R6	S6
	codellama7b S1	S2	S5	D4
	starchat S1	S2	D5	R4
CWE-416	codellama13b S1	S2	R6	R4
	codellama7b S1	S2	R6	D3
	starchat S1	S2	R6	S6
CWE-476	codellama13b S1	S2	S5	R4
	codellama7b R1	S4	S5	D3
	starchat R3	D2	R6	D4
CWE-77	codellama13b S1	S2	S5	S6
	codellama7b R1	S4	R6	R4
	starchat S1	S2	D5	D3
CWE-787	codellama13b S1	S3	S5	D3
	codellama7b S1	S2	R6	R4
	starchat S1	S2	S5	D3
CWE-79	codellama13b S1	S3	S5	S6
	codellama7b R3	R2	S5	D4
	starchat S1	S2	S5	R5
CWE-89	codellama13b D1	S2	S5	R4
	codellama7b S1	S2	S5	S6
	starchat S1	S2	D5	S6

```

1 ...
2 void read_file(char* file_name)
3 {
4     char* dir = "/Users/user1/";
5     int file_path_len = strlen(dir) + strlen(file_name) +
6     1;
7     char* file_path = malloc(file_path_len);
8     ...
9     strcpy(file_path, dir);
10    strcat(file_path, file_name);
11
12    FILE* f = fopen(file_path, "r");
13    ...
14    /* read file */

```

(a) CWE-22 (1_v) Easy Code Difficulty Level

```

1 ...
2 void file_operation(char* flag, char* file_name, char*
3 data)
4 {
5     char* dir = getenv("dir");
6     ...
7     char* resolved_dir = realpath(dir, NULL);
8     if (resolved_dir == NULL)
9     {
10        printf("Invalid path\n");
11        return;
12    }
13
14    char* path = malloc(strlen(resolved_dir) + strlen(
15    file_name) + 1);
16    ...
17    strcpy(path, resolved_dir);
18    strcat(path, file_name);
19
20    FILE* f = fopen(path, flag);
21    ...
22    if (*flag == 'w')
23    {
24        /* write */
25    }
26    else if (*flag == 'r')
27    {
28        /* read */
29    }

```

(b) CWE-22 (2_v) Medium Difficulty Level

```

1 ...
2 void resolve_path(char* path)
3 {
4     char* p = path;
5     while (*p != '\0') {
6         if (*p == ' ') {
7             *p = '-';
8             p++;
9         }
10    }
11
12    void print_file(char* file_name)
13    {
14        char* dir = getenv("dir");
15        ...
16
17        int path_len = strlen(dir) + strlen(file_name) + 1;
18        char* path = malloc(path_len);
19        ...
20        strcpy(path, dir);
21        strcat(path, file_name);
22        resolve_path(path);
23        FILE* f = fopen(path, "r");
24        ...
25    }

```

(c) CWE-22 (3_v) Hard Difficulty Level

Figure 9: Examples of Different Difficulty Levels

```

1 #define FGETS(buffer, buffer_len, stdin) gets(buffer)
2
3 #define SAFE_EXECUTION(cmd) system(cmd)
4
5 #define STRNCPY(dest, src, n) strcpy(dest, src)

```

Figure 10: #define expressions for ‘NT6’ code augmentations

```

1 ...
2 char* validate_cmd(char* cmd) {
3     char* new_cmd = malloc(strlen(cmd) + 1);
4     int cmd_ix = 0;
5     while (cmd_ix < strlen(cmd)) {
6         if (cmd[cmd_ix] == ';' ) {
7             break;
8         }
9         new_cmd[cmd_ix] = cmd[cmd_ix];
10        cmd_ix++;
11    }
12    return new_cmd;
13 }
14 ...

```

Figure 11: CWE-77 (Command Injection) 3_v code scenario.

TABLE 25: Evaluation code difficulties (Ext. Table 14).

		Best Prompts							
Model		ZS - TO		ZS - RO		FS - TO		FS - RO	
Easy	codellama13b	D1	0/16	S2	0/16	S5	11/16	D3	10/16
	codellama7b	R3	9/16	S3	8/16	S5	10/16	D4	10/16
	starchat	R3	10/16	D2	9/16	R6	10/16	S6	10/16
Medium	codellama13b	S1	9/16	S3	8/16	S5	10/16	R5	9/16
	codellama7b	R1	8/16	D2	9/16	R6	7/16	S6	9/16
	starchat	S1	8/16	S2	8/16	D5	11/16	D3	9/16
Hard	codellama13b	S1	8/16	S2	8/16	S5	8/16	S6	8/16
	codellama7b	R1	8/16	D2	8/16	D5	9/16	D4	9/16
	starchat	S1	8/16	S2	8/16	D5	9/16	D3	10/16

TABLE 26: Evaluation Code-Level Augmentations (Ext. Table 15).

		T1		T2		T3		T4		T5		T6		T7	
M	PS	Δ_a	Δ_r	Δ_a	Δ_r	Δ_a	Δ_r	Δ_a	Δ_r	Δ_a	Δ_r	Δ_a	Δ_r	Δ_a	Δ_r
c.lia.7b	S1s	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	1/12
	D2s	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12
	D4s	2/12	3/12	2/12	2/12	1/12	1/12	3/12	3/12	1/12	1/12	1/12	1/12	2/12	3/12
	S5s	0/12	0/12	1/12	1/12	0/12	0/12	2/12	2/12	0/12	0/12	1/12	1/12	0/12	0/12
c.lia.13b	S1s	0/12	0/12	1/12	1/12	0/12	0/12	2/12	2/12	0/12	0/12	1/12	1/12	0/12	0/12
	S12s	0/12	0/12	1/12	1/12	0/12	0/12	2/12	2/12	0/12	0/12	1/12	1/12	0/12	0/12
	S5s	0/12	0/12	1/12	1/12	2/12	2/12	2/12	2/12	0/12	0/12	3/12	3/12	0/12	0/12
	S5s	0/12	0/12	1/12	1/12	2/12	2/12	2/12	2/12	0/12	0/12	3/12	3/12	0/12	0/12
starc.	S1s	0/12	0/12	0/12	0/12	0/12	0/12	1/12	1/12	0/12	0/12	0/12	0/12	0/12	0/12
	D2s	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12	0/12
	D3s	0/12	0/12	2/12	2/12	7/12	4/12	0/12	1/12	1/12	1/12	3/12	6/12	4/12	4/12
	D3s	0/12	0/12	2/12	2/12	7/12	4/12	0/12	1/12	1/12	1/12	3/12	6/12	4/12	4/12

(a) Trivial Augmentations

		NT1		NT2		NT3		NT4		NT5		NT6	
M	PS	Δ_a	Δ_r	Δ_a	Δ_r	Δ_a	Δ_r	Δ_a	Δ_r	Δ_a	Δ_r	Δ_a	Δ_r
c.lia.7b	S1s	0/12	0/12	0/12	0/12	3/12	3/12	0/12	4/12	0/9	1/9	0/9	0/9
	D2s	0/12	0/12	0/12	0/12	9/12	8/12	0/12	2/12	0/9	0/9	0/9	0/9
	D4s	3/12	3/12	4/12	8/12	2/12	2/12	5/12	6/12	0/9	0/9	0/9	0/9
	D4s	3/12	3/12	4/12	8/12	2/12	2/12	5/12	6/12	0/9	0/9	0/9	0/9
c.lia.13b	S1s	1/12	0/12	2/12	2/12	8/12	8/12	1/12	3/12	0/9	0/9	0/9	4/9
	S12s	1/12	0/12	2/12	2/12	8/12	8/12	1/12	4/12	0/9	0/9	0/9	2/9
	S5s	0/12	0/12	5/12	5/12	10/12	10/12	1/12	2/12	0/9	0/9	3/9	4/9
	S5s	0/12	0/12	5/12	5/12	10/12	10/12	1/12	2/12	0/9	0/9	3/9	4/9
starc.	S1s	0/12	0/12	0/12	0/12	0/12	1/12	0/12	3/12	0/9	0/9	1/9	1/9
	D2s	0/12	0/12	3/12	3/12	6/12	5/12	0/12	2/12	0/9	3/9	0/9	0/9
	D3s	0/12	2/12	1/12	1/12	4/12	4/12	0/12	1/12	1/9	1/9	1/9	1/9
	D3s	0/12	2/12	1/12	1/12	4/12	4/12	0/12	1/12	1/9	1/9	1/9	1/9

(b) Non-Trivial Augmentations

TABLE 27: Evaluation real-world CVEs (Ext. Tables 16 and 17).

		ZS - TO		ZS - RO		FS - TO		FS - RO	
Model		v	p	v	p	v	p	v	p
gptac 2023-1452	codellama7b	✓	✓	✗	✗	✗	✗	✗	✗
	codellama13b	✓	✓	✓	✓	✓	✓	✗	✗
	starchat	✓	✓	✗	✗	✗	✗	✗	✗
gptac 2023-23143	codellama7b	✓	✓	✗	✗	✗	✗	✗	✗
	codellama13b	✓	✓	✗	✗	✓	✓	✗	✗
	starchat	✓	✓	✗	✗	✗	✗	✗	✗
gptac 2023-23144	codellama7b	✗	✓	✗	✗	✗	✗	✗	✗
	codellama13b	✓	✓	✓	✓	✓	✓	✗	✗
	starchat	✓	✓	✗	✗	✗	✗	✗	✗
gptac 2023-3012	codellama7b	✓	✓	✗	✗	✗	✗	✗	✗
	codellama13b	✓	✓	✗	✗	✓	✓	✗	✗
	starchat	✓	✓	✗	✗	✗	✗	✗	✗
libtiff 2023-26966	codellama7b	✗	✗	✗	✗	✗	✗	✗	✗
	codellama13b	✓	✓	✗	✗	✗	✗	✗	✗
	starchat	✓	✓	✗	✗	✗	✗	✓	✗
libtiff 2023-2908	codellama7b	✓	✓	✗	✗	✗	✗	✗	✗
	codellama13b	✓	✓	✓	✓	✓	✓	✗	✗
	starchat	✓	✓	✗	✗	✗	✗	✗	✗
libtiff 2023-3316	codellama7b	✓	✓	✗	✗	✗	✗	✗	✗
	codellama13b	✓	✓	✓	✓	✓	✓	✗	✗
	starchat	✓	✓	✗	✗	✗	✗	✗	✗
libtiff 2023-40745	codellama7b	✓	✓	✗	✗	✗	✗	✗	✗
	codellama13b	✓	✓	✗	✗	✓	✓	✓	✗
	starchat	✓	✓	✗	✗	✗	✗	✗	✗
libtiff 2023-41175	codellama7b	✓	✓	✗	✗	✗	✗	✗	✗
	codellama13b	✓	✓	✓	✗	✓	✓	✗	✗
	starchat	✓	✓	✓	✗	✗	✗	✓	✗
linux 2023-40283	codellama7b	✓	✓	✗	✗	✗	✗	✗	✗
	codellama13b	✓	✓	✓	✓	✓	✓	✗	✗
	starchat	✓	✓	✗	✗	✗	✓	✓	✗
linux 2023-42753	codellama7b	✓	✓	✗	✗	✗	✗	✗	✗
	codellama13b	✓	✓	✗	✗	✓	✓	✗	✗
	starchat	✓	✓	✗	✗	✗	✗	✓	✗
linux 2023-42754	codellama7b	✗	✗	✗	✗	✗	✗	✗	✗
	codellama13b	✓	✓	✓	✓	✗	✗	✗	✗
	starchat	✓	✓	✗	✗	✓	✗	✗	✗
linux 2023-45863	codellama7b	✗	✗	✗	✗	✗	✗	✗	✗
	codellama13b	✓	✓	✓	✓	✓	✗	✓	✓
	starchat	✓	✓	✓	✓	✗	✗	✗	✗
linux 2023-45871	codellama7b	✗	✗	✗	✗	✗	✗	✗	✗
	codellama13b	✗	✗	✗	✗	✓	✓	✗	✗
	starchat	✓	✓	✗	✗	✗	✗	✗	✗
psip 2023-27585	codellama7b	✓	✗	✗	✗	✗	✗	✗	✗
	codellama13b	✗	✗	✓	✓	✗	✗	✗	✗
	starchat	✓	✓	✗	✗	✗	✗	✗	✗

Appendix C. Meta-Review

The following meta-review was prepared by the program committee for the 2024 IEEE Symposium on Security and Privacy (S&P) as part of the review process as detailed in the call for papers.

C.1. Summary

This paper suggests an automated framework for evaluating LLMs (Large Language Models) for identifying and reasoning about security vulnerabilities. The authors conducted experiments on various options of LLMs (e.g., prompts, models, test data) and presented various interesting findings.

C.2. Scientific Contributions

- Provides a Valuable Step Forward in an Established Field
- Creates a New Tool to Enable Future Science
- Provides a New Data Set For Public Use

C.3. Reasons for Acceptance

- 1) This paper suggests a fully automated framework to evaluate various aspects of LLM's capability in identifying vulnerabilities, which is gaining more attention from the community.
- 2) The paper examines several aspects that have been less studied previously, including code complexity, vulnerability reasoning, and use of chat-based LLMs (e.g., GPT-4) in vulnerability detection.
- 3) The authors have developed a new benchmark consisting of 228 code scenarios. This includes 48 hand-crafted examples (starting from most critical CWEs), 30 examples from real-world CVEs (taken from open source projects) and 150 codes obtained by trivial and non-trivial augmentation. If released, this dataset can help in carrying out further research, allowing an alignment for future analysis.

C.4. Noteworthy Concerns

- 1) Some findings seem well-known to the community (e.g., non-determinism, and non-robustness by specific code augmentations).
- 2) The size of the data set is still limited, especially for the real-world CVEs (the data set only includes 15 CVEs now). Moreover, the dataset includes many augmented codes (150/228). The small data set may lead to significant bias in the measurement results, making it less reliable.

Appendix D. Response to the Meta-Review

We thank the reviewers for their valuable feedback and the shepherd for helping us improve the paper. We would like to respond to the meta-review concerns as follows:

- 1) While instances of non-determinism and non-robustness to specific code augmentations have been found in previous work, to the best of our knowledge we are the first ones to systematically evaluate these issues in the context of vulnerability detection.
- 2) The size of our dataset is comparable to previous work like [8] which only used 12 CVEs. In our study, the number of suitable CVEs was constrained by the knowledge cut-off date of LLMs (to maintain the temporal consistency of our evaluation [30]), by the CWE types in our evaluation study, and by needing CVEs with high-quality patch commits.